

Dédicace

À mes parents, pour leur soutien indéfectible.

À tous ceux qui m'ont accompagné dans ce parcours.

Rania

Remerciements

Nous tenons à exprimer notre profonde gratitude à notre encadrante pour sa disponibilité, ses conseils avisés et son soutien tout au long de ce travail.

Nous remercions également les membres du jury d'avoir accepté d'évaluer ce mémoire.

Nos remerciements vont aussi à l'ensemble du corps enseignant de notre établissement pour la qualité de la formation dispensée.

Enfin, nous adressons nos sincères remerciements à nos familles et amis pour leur soutien moral constant.

Résumé

Les attaques par déni de service distribué (Distributed Denial of Service (DDoS)) constituent l'une des menaces les plus critiques pour la disponibilité des services numériques modernes. Face à l'augmentation exponentielle de leur volume et de leur sophistication, les approches de mitigation centralisées montrent leurs limites : points de défaillance uniques, coûts élevés et absence de coordination entre acteurs indépendants.

Ce mémoire présente la conception et l'implémentation d'un système distribué de mitigation collaborative des attaques DDoS, reposant sur une coalition pair-à-pair de nœuds de protection hétérogènes. Le système propose trois contributions principales : (1) un mécanisme de confiance fondé sur le modèle PeerTrust, adapté avec une crédibilité historique par session garantissant une évaluation fidèle à la réalité temporelle du réseau ; (2) un algorithme de sélection multicritère des pairs assistants basé sur le Weighted Sum Model avec pondération Analytic Hierarchy Process (AHP), prenant en compte la capacité disponible, la latence, la confiance et la réciprocité ; (3) une sécurisation de bout en bout des communications inter-nœuds par mTLS et JWT RS256 sans secret partagé.

Le prototype, développé en Node.js avec PostgreSQL, a été évalué sur une coalition simulée de 20 à 100 nœuds. Les résultats démontrent un taux de succès de 100 % pour l'ensemble des opérations testées, avec un temps de sélection Weighted Sum Model (WSM) inférieur à 33 ms quelle que soit la taille de la coalition.

Mots-clés : DDoS, mitigation collaborative, pair-à-pair, confiance, PeerTrust, Weighted Sum Model, mTLS, JWT, sécurité réseau.

Abstract

Distributed Denial of Service (DDoS) attacks represent one of the most critical threats to the availability of modern digital services. As their volume and sophistication grow exponentially, centralized mitigation approaches show their limitations : single points of failure, high costs, and lack of coordination between independent actors.

This thesis presents the design and implementation of a distributed collaborative DDoS mitigation system based on a peer-to-peer coalition of heterogeneous protection nodes. The system proposes three main contributions : (1) a trust mechanism based on the PeerTrust model, extended with per-session historical credibility to ensure evaluation faithful to the temporal reality of the network ; (2) a multi-criteria peer selection algorithm based on the Weighted Sum Model with AHP weighting, considering available capacity, latency, trust and reciprocity ; (3) end-to-end security of inter-node communications via mutual TLS and JWT RS256 without shared secrets.

The prototype, developed in Node.js with PostgreSQL, was evaluated on a simulated coalition ranging from 20 to 100 nodes. Results demonstrate a 100 % success rate for all tested operations, with WSM selection time below 33 ms regardless of coalition size.

Keywords : DDoS, collaborative mitigation, peer-to-peer, trust, PeerTrust, Weighted Sum Model, mTLS, JWT, network security.

Table des matières

Dédicace	I
Remerciements	II
Résumé	III
Abstract	IV
Table des matières	VIII
Liste des acronymes	IX
Liste des abréviations	X
Liste des figures	XII
Liste des tableaux	XIII
Introduction générale	1
Contexte	2
Problématique	2
Objectifs	2
Périmètre du travail	3
Organisation du rapport	3
1 Contexte et concepts fondamentaux	5
1.1 Introduction	5
1.2 Les attaques par déni de service distribué (DDoS)	5
1.2.1 Définition	5
1.2.2 Architecture d'une attaque DDoS	5
1.2.3 Classification des attaques DDoS	6
1.2.3.1 Attaques volumétriques	6
1.2.3.2 Attaques sur les protocoles réseau	6
1.2.3.3 Attaques applicatives (couche 7)	7
1.2.4 Impact et données statistiques	7
1.3 Infrastructure de mitigation DDoS	8
1.3.1 Les <i>scrubbing centers</i> : définition et rôle	8
1.3.2 Les réseaux de diffusion de contenu (CDN) comme bouclier anti-DDoS	8
1.3.3 Les pare-feu et systèmes de prévention d'intrusion (IPS)	9
1.3.3.1 Pare-feu traditionnels et nouvelle génération (NGFW) . . .	9

1.3.3.2	Systèmes de prévention d'intrusion (IPS)	10
1.3.4	Le <i>blackholing</i> et le RTBH (<i>Remote Triggered Black Hole</i>)	10
1.3.5	Les services de mitigation cloud (<i>Cloud-based DDoS Protection</i>)	11
1.3.6	Techniques de redirection du trafic	12
1.3.7	Synthèse et comparaison des infrastructures de mitigation	12
1.3.8	Limites des approches centralisées	13
1.4	Architecture pair-à-pair pour la coordination inter-nœuds	13
1.4.1	Définition et pertinence du modèle pair-à-pair	13
1.4.2	Topologies et protocoles P2P applicables à la mitigation	14
1.4.3	Défis du P2P appliqué à la sécurité réseau	15
1.5	Conclusion	15
2	Étude bibliographique	16
2.1	Introduction	16
2.2	DOTS — DDoS Open Threat Signaling	16
2.2.1	Contexte et motivation	16
2.2.2	Architecture et fonctionnement	16
2.2.2.1	Canal de signalisation (<i>Signal Channel</i>)	16
2.2.2.2	Canal de données (<i>Data Channel</i>)	17
2.2.3	Limites identifiées	18
2.3	DDoS Clearing House — Partage collaboratif de <i>fingerprints</i>	18
2.3.1	Contexte et motivation	18
2.3.2	Architecture et fonctionnement	18
2.3.2.1	Le <i>DDoS Fingerprint</i> : structure et contenu	18
2.3.2.2	Architecture logicielle	19
2.3.3	Limites identifiées	19
2.4	NaWas / NBIP — Centre national de <i>scrubbing</i> mutualisé	20
2.4.1	Contexte et architecture	20
2.4.1.1	Mécanisme de redirection BGP	20
2.4.2	Limites identifiées	21
2.5	DefCOM — <i>Distributed Cooperative Overlay Defense</i>	22
2.5.1	Contexte et architecture	22
2.5.1.1	Topologie et rôles des nœuds	22
2.5.1.2	Mécanisme de <i>Rate Limiting</i> coopératif	22
2.5.1.3	Protocole de communication overlay	23
2.5.2	Limites identifiées	23
2.6	Synthèse comparative	25
2.7	Conclusion	25
3	Conception et Architecture du système	26
3.1	Introduction	26
3.2	Conception préliminaire	26
3.2.1	Périmètre du système	26
3.2.2	Objectifs et exigences du système	27
3.2.3	Diagrammes de cas d'utilisation	27
3.2.3.1	Protocole de mitigation collaborative	27
3.2.3.2	Moteur de confiance PeerTrust	28
3.2.3.3	Rôle du nœud pair dans la coalition	29
3.2.4	Documentation des cas d'utilisation	32

3.2.5	Architecture générale	39
3.2.5.1	Topologie de la coalition	39
3.2.5.2	Cycle de vie d'une session de mitigation	39
3.3	Conception technique détaillée	40
3.3.1	Modèle de données	40
3.3.1.1	Schéma entité-association	40
3.3.1.2	Identifiants et intégrité référentielle	41
3.3.2	Modèle de confiance : PeerTrust adapté	41
3.3.2.1	Motivation du choix de PeerTrust	41
3.3.2.2	Formule $T(u)$ et ses paramètres	41
3.3.2.3	Niveaux de confiance	43
3.3.3	Algorithme de sélection des pairs : WSM	43
3.3.3.1	Critères de sélection	43
3.3.3.2	Pondération AHP	44
3.3.3.3	Répartition proportionnelle du flux	44
3.3.4	Diagramme d'activités : session de mitigation	45
3.3.5	Mécanismes de sécurité	47
3.3.5.1	Transport sécurisé : mTLS	47
3.3.5.2	Authentification applicative : JWT RS256	47
3.3.6	Interface API REST	47
3.3.6.1	Style architectural	47
3.3.6.2	Endpoints	48
3.4	Conclusion	48
4	Implémentation et Évaluation	50
4.1	Introduction	50
4.2	Environnement technique	50
4.2.1	Pile technologique	50
4.2.2	Structure du projet	51
4.3	Implémentation du gestionnaire de confiance	51
4.3.1	Calcul de $T(u)$ avec Cr historique	51
4.3.2	Capture de la crédibilité à la clôture	52
4.3.3	Persistance et sanctions automatiques	53
4.4	Implémentation de la sélection des pairs	53
4.4.1	Calcul du score WSM	53
4.4.2	Plan de répartition proportionnelle	53
4.5	Mécanismes de sécurité	54
4.5.1	JWT RS256 : génération et vérification	54
4.5.2	mTLS : configuration côté serveur	54
4.6	Protocole de communication inter-nœuds	55
4.6.1	Authentification	55
4.6.2	Heartbeat	55
4.6.3	Détection d'une attaque	56
4.6.4	Demande et réponse d'aide	56
4.6.5	Redirection du trafic et clôture	57
4.7	Tests et évaluation	58
4.7.1	Protocole de test	58
4.7.2	Résultats des tests de scalabilité	59

4.8 Conclusion	59
Bibliographie	61

Liste des abréviations

Abréviation	Signification
ACL	Access Control List
AHP	Analytic Hierarchy Process
API	Application Programming Interface
AS	Autonomous System
BGP	Border Gateway Protocol
CBOR	Concise Binary Object Representation
CoAP	Constrained Application Protocol
DDoS	Distributed Denial of Service
DHT	Distributed Hash Table
DoS	Denial of Service
DOTS	DDoS Open Threat Signaling
DPI	Deep Packet Inspection
DTLS	Datagram Transport Layer Security
FAI	Fournisseur d'Accès Internet
GRE	Generic Routing Encapsulation
IoT	Internet of Things
JWT	JSON Web Token
mTLS	Mutual Transport Layer Security
NLRI	Network Layer Reachability Information
ORM	Object-Relational Mapping
P2P	Pair-à-Pair
REST	Representational State Transfer
RSA	Rivest-Shamir-Adleman
RTT	Round-Trip Time
SPOF	Single Point of Failure

Abréviation	Signification
TLS	Transport Layer Security
UUID	Universally Unique Identifier
WAF	Web Application Firewall
WSM	Weighted Sum Model

Table des figures

1.1	Architecture générale d'une attaque DDoS.	6
1.2	Processus de mitigation via un <i>scrubbing center</i>	8
1.3	Principe de protection anti-DDoS par un CDN avec Anycast.	9
1.4	Mécanisme de RTBH via BGP : la victime annonce un préfixe avec une communauté RTBH, et le FAI redirige le trafic correspondant vers <code>null0</code>	10
2.1	Architecture de référence du protocole DDoS Open Threat Signaling (DOTS) : séparation entre le canal de signalisation (CoAP/DTLS/UDP) et le canal de données (RESTCONF/HTTPS/TCP).	17
2.2	Architecture du <i>DDoS Clearing House</i> : génération d'empreintes DDoS par le composant Dissector, stockage dans la base DDoS DB, puis utilisation par l'équipe opérationnelle pour générer des règles de mitigation.	20
2.3	Architecture simplifiée du service NaWas : redirection du trafic vers un centre de scrubbing mutualisé via annonce BGP et analyse des flux avant application des mécanismes de mitigation.	21
2.4	Arbre de limitation de débit coopératif dans DefCOM : propagation de la demande de la victime vers les sources.	24
3.1	Diagramme de cas d'utilisation : Protocole de mitigation collaborative.	28
3.2	Diagramme de cas d'utilisation : Moteur de confiance PeerTrust.	29
3.3	Diagramme de cas d'utilisation : Rôle du nœud pair dans la coalition (12 cas d'usage).	31
3.4	Exemple de coalition : sept nœuds hétérogènes interconnectés en overlay Pair-à-Pair (P2P) plat non structuré.	39
3.5	Schéma entité-association de la base de données locale d'un nœud.	40
3.6	Diagramme d'activités d'une session de mitigation collaborative (deux couloirs : nœud victime et nœud pair).	46
4.1	Structure des répertoires du projet.	51
4.2	Temps de réponse en fonction du nombre de nœuds simulés (enregistrement, heartbeat et sélection WSM).	59

Liste des tableaux

1.1	Synthèse comparative des catégories d'attaques DDoS.	7
1.2	Comparaison des principaux services de mitigation cloud.	11
1.3	Comparaison des infrastructures de mitigation DDoS.	12
2.1	Comparaison des systèmes de défense collaborative contre les attaques DDoS.	25
3.1	Documentation du cas d'utilisation <i>Obtenir un token JWT RS256</i>	32
3.2	Documentation du cas d'utilisation <i>S'enregistrer dans la coalition</i>	33
3.3	Documentation du cas d'utilisation <i>Envoyer un heartbeat</i>	34
3.4	Documentation du cas d'utilisation <i>Envoyer une requête d'aide (sélection WSM)</i>	35
3.5	Documentation du cas d'utilisation <i>Accepter ou rejeter une session d'aide</i>	36
3.6	Documentation du cas d'utilisation <i>Clôturer l'attaque</i>	37
3.7	Documentation du cas d'utilisation <i>Recalculer le score PeerTrust</i>	38
3.8	Description des tables de la base de données.	42
3.9	Facteur contextuel $D(u, i)$ selon la sévérité de l'attaque.	43
3.10	Niveaux de confiance dans le système.	44
3.11	Matrice AHP de comparaison des critères de sélection des pairs.	44
3.12	Endpoints principaux de l'API REST.	48
4.1	Pile technologique du système.	50
4.2	Résultats des tests de scalabilité (20 à 100 nœuds).	59

Introduction générale

La transformation numérique massive des organisations, l’essor du cloud et de l’Internet des objets (Internet of Things (IoT)) ont profondément renforcé la dépendance aux infrastructures réseau et aux systèmes d’information. La disponibilité continue des services numériques est devenue une exigence fondamentale, tant pour les acteurs économiques que pour les institutions et les utilisateurs. Dans cet environnement fortement interconnecté, toute interruption de service peut engendrer des conséquences opérationnelles, financières et réputationnelles significatives.

Les attaques par déni de service distribué (DDoS) constituent aujourd’hui l’une des principales menaces affectant la disponibilité des services numériques. Ces attaques consistent à générer un volume massif de trafic malveillant, distribué à partir de multiples sources, dans le but de saturer les ressources d’une cible et d’entraîner une indisponibilité partielle ou totale du service. Leur simplicité conceptuelle contraste avec leur efficacité opérationnelle, notamment lorsqu’elles exploitent des infrastructures distribuées à grande échelle et des botnets composés de milliers, voire de millions de dispositifs compromis.

Selon le rapport Cloudflare sur les menaces DDoS au premier trimestre 2025, 20,5 millions d’attaques ont été identifiées, soit une augmentation de 358 % par rapport à l’année précédente [2]. Certains incidents récents ont atteint des volumes dépassant plusieurs téraoctets par seconde, illustrant la capacité des attaquants à mobiliser des botnets massifs et des infrastructures distribuées à grande échelle.

Les secteurs les plus ciblés incluent notamment la finance, les télécommunications, les services en ligne à forte disponibilité, ainsi que les infrastructures publiques et les plateformes de commerce électronique. Les attaques multi-vecteurs, combinant saturation volumétrique, exploitation de protocoles réseau et ciblage applicatif (couche 7), représentent désormais une part significative des incidents observés, rendant les mécanismes de défense traditionnels plus difficiles à maintenir efficaces.

Les solutions actuelles reposent majoritairement sur des architectures centralisées, telles que les *scrubbing centers* ou les services de mitigation cloud. Bien que ces solutions offrent une capacité de traitement élevée, elles présentent des limites structurelles : dépendance à un point unique de décision, latence due à la redirection du trafic, coûts élevés et absence de coordination dynamique entre acteurs indépendants.

Face à ces limites, une nouvelle approche émerge : la **défense collaborative distribuée**. Plutôt que de traiter les attaques de manière isolée, plusieurs entités autonomes peuvent coopérer afin de partager des informations, synchroniser leurs actions et renforcer leur résilience collective. C’est dans ce cadre que s’inscrit ce projet de fin d’études, visant à concevoir une infrastructure de coordination inter-nœuds pour la défense collaborative contre les attaques DDoS.

Contexte

Les solutions classiques de mitigation DDoS reposent majoritairement sur des architectures centralisées, telles que des centres de nettoyage du trafic (*scrubbing centers*) ou des services cloud spécialisés. Ces approches permettent d'absorber de forts volumes de trafic malveillant et d'appliquer des mécanismes de filtrage avancés. Toutefois, elles présentent plusieurs limites structurelles.

D'une part, la centralisation introduit des points de concentration critiques, susceptibles de devenir eux-mêmes des goulots d'étranglement ou des cibles d'attaque. D'autre part, les coûts associés à ces services peuvent être significatifs, ce qui limite leur accessibilité pour certaines organisations, notamment les PME et les collectivités. Enfin, la latence induite par la redirection du trafic vers des infrastructures distantes peut impacter la qualité de service.

Parallèlement, l'évolution des menaces complexifie la détection et la coordination des réponses. Les attaques modernes exploitent des botnets massifs, des vulnérabilités applicatives et des techniques d'évasion sophistiquées. Elles peuvent évoluer dynamiquement en fonction des contre-mesures mises en place. Face à ces attaques adaptatives, une simple réaction locale et isolée montre rapidement ses limites.

Dans ce cadre, l'idée d'une défense collaborative et distribuée — reposant sur la coordination entre plusieurs nœuds de protection capables d'échanger des informations en temps réel et de mutualiser leurs ressources — apparaît comme une piste pertinente et innovante.

Problématique

Les attaques DDoS atteignent aujourd'hui des volumes et une complexité qui dépassent les capacités de mitigation d'infrastructures isolées. Face à cette menace, les organisations utilisent principalement des solutions centralisées : *scrubbing centers* ou services cloud de mitigation.

Ces architectures présentent plusieurs limitations techniques :

- dépendance aux prestataires externes ;
- coûts élevés pour les PME et collectivités ;
- latence due à la redirection du trafic ;
- points uniques de défaillance (Single Point of Failure (SPOF)) ;
- absence de mutualisation des ressources de défense.

De plus, la défense reste individuelle. Les mécanismes actuels se limitent au partage d'informations, sans mutualisation opérationnelle des capacités de mitigation ni coordination des contre-mesures. En cas d'attaque distribuée touchant plusieurs cibles simultanément, chaque organisation réagit de son côté, ce qui réduit l'efficacité globale.

Objectifs

L'objectif principal de ce projet est de concevoir et d'implémenter un mécanisme de coordination inter-nœuds destiné à renforcer la défense collaborative contre les attaques DDoS.

Pour atteindre cet objectif, le travail consiste à :

1. Réaliser une étude approfondie des attaques DDoS, des mécanismes de mitigation existants et des approches collaboratives en environnement distribué.
2. Analyser les limites des solutions centralisées actuelles et identifier les besoins en matière de coordination et de partage de ressources entre nœuds autonomes.
3. Définir les principaux cas d’usage de coordination entre nœuds de protection, notamment l’alerte, l’entraide et la redirection de trafic.
4. Concevoir un protocole distribué d’échange inter-nœuds précisant les règles de communication et de prise de décision.
5. Développer un prototype permettant l’échange sécurisé de métadonnées d’attaque et la synchronisation des actions de mitigation entre plusieurs nœuds.
6. Mettre en place un environnement de test simulant un réseau de nœuds coopérants afin d’évaluer la robustesse, la latence et la cohérence des mécanismes proposés.
7. Réaliser une documentation technique détaillant l’architecture et le fonctionnement du système développé.

Périmètre du travail

Ce travail se concentre exclusivement sur les **échanges inter-nœuds** au sein d’une coalition de défense déjà constituée. Plus précisément, le périmètre couvre :

- la conception et l’implémentation de l’**API REST** exposée par chaque nœud pour la coordination collaborative ;
- le **protocole d’aide** entre nœuds : signalement d’attaque, demande et acceptation de sessions de mitigation, redirection de trafic, clôture ;
- le **mécanisme de confiance** fondé sur PeerTrust : calcul des scores, détection des violations, exclusion automatique ;
- la **sécurisation des communications** inter-nœuds par mTLS et JWT RS256.

Les aspects suivants sont explicitement **hors périmètre** :

- la formation du réseau P2P (bootstrap, découverte initiale des pairs, protocoles de routage overlay) ;
- la détection technique des attaques DDoS au niveau réseau (analyse de trafic, deep packet inspection) ;
- le filtrage et le nettoyage effectif du trafic (scrubbing) au sein de chaque nœud ;
- la gestion des tunnels de redirection au niveau infrastructure (configuration GRE, BGP Flowspec).

Organisation du rapport

Le présent mémoire est structuré en quatre chapitres :

- **Chapitre 1 : Contexte et concepts fondamentaux.** Ce chapitre présente les fondements théoriques des attaques DDoS, la taxonomie des vecteurs d’attaque et les mécanismes de mitigation existants (*scrubbing centers*, CDN, pare-feu, RTBH, services cloud), ainsi que les principes des architectures pair-à-pair applicables à la coordination inter-nœuds.
- **Chapitre 2 : État de l’art.** Ce chapitre analyse les principales approches collaboratives et distribuées de défense contre les attaques DDoS : le protocole de

signalisation DOTS, la DDoS Clearing House, la mutualisation opérationnelle Na-Was/NBIP et l'overlay coopératif DefCOM. Une synthèse comparative identifie les lacunes motivant la contribution de ce mémoire.

- **Chapitre 3 : Conception et Architecture du système.** Ce chapitre décrit les décisions de conception du système : topologie P2P de la coalition, modèle de données, mécanisme de confiance fondé sur PeerTrust, algorithme de sélection des pairs par WSM avec pondération AHP, protocoles de sécurité mTLS et JWT RS256, et interface Application Programming Interface (API) Representational State Transfer (REST).
- **Chapitre 4 : Implémentation et Évaluation.** Ce chapitre présente la réalisation concrète du prototype : pile technologique, implémentation du gestionnaire de confiance et du sélecteur de pairs, configuration de la sécurité, et résultats des tests de scalabilité conduits sur une coalition simulée jusqu'à 100 nœuds.

Enfin, une **conclusion générale** synthétise les contributions du travail et propose des perspectives d'évolution.

Chapitre 1

Contexte et concepts fondamentaux

1.1 Introduction

La sécurité des infrastructures réseau est aujourd’hui l’un des enjeux majeurs de l’informatique moderne. Parmi les menaces les plus dévastatrices, les attaques par déni de service distribué (DDoS) occupent une place prépondérante, en raison de leur capacité à paralyser des services critiques en saturant les ressources d’un ou plusieurs systèmes cibles.

Face à l’augmentation en volume et en sophistication de ces attaques, les approches de mitigation centralisées montrent rapidement leurs limites. Il devient alors indispensable d’envisager des mécanismes de défense collaborative et distribuée, où plusieurs nœuds de protection — notamment des *scrubbing centers* — coordonnent leurs actions en temps réel pour détecter, analyser et contrer ces menaces de manière collective.

Ce chapitre a pour objectif de poser les bases conceptuelles nécessaires à la compréhension du travail présenté dans ce mémoire. Nous abordons successivement la nature et la classification des attaques DDoS, les mécanismes d’infrastructure de mitigation existants, puis les principes des systèmes distribués appliqués à la coordination inter-nœuds.

1.2 Les attaques par déni de service distribué (DDoS)

1.2.1 Définition

Une attaque par déni de service (Denial of Service (DoS)) désigne toute action malveillante visant à rendre un service informatique indisponible pour ses utilisateurs légitimes, en épuisant les ressources du système cible (bande passante, mémoire, CPU, connexions). Lorsque cette attaque est menée simultanément depuis un grand nombre de machines distribuées, on parle d’attaque DDoS [12].

Mirkovic et Reiher définissent une attaque DDoS comme : « une tentative explicite d’un attaquant de nier aux utilisateurs légitimes l’utilisation d’un service réseau, en submergeant la cible ou son infrastructure intermédiaire avec du trafic illégitime » [13].

1.2.2 Architecture d’une attaque DDoS

Une attaque DDoS repose sur une architecture à plusieurs niveaux impliquant différents acteurs (voir Figure 1.1) :

- **L’attaquant (*handler*)** : l’entité malveillante qui orchestre l’attaque depuis une machine maîtresse.
- **Le réseau de commande et contrôle (C&C)** : infrastructure permettant à l’attaquant de coordonner les agents d’attaque à distance, souvent dissimulée via des protocoles légitimes (IRC, HTTP, P2P).
- **Les agents (*zombies* / *bots*)** : machines compromises (ordinateurs, serveurs, objets connectés IoT) qui exécutent les instructions reçues du C&C et génèrent le trafic malveillant.
- **La cible (*victime*)** : le système dont on cherche à épuiser les ressources — serveur web, infrastructure DNS, routeurs de transit, etc.

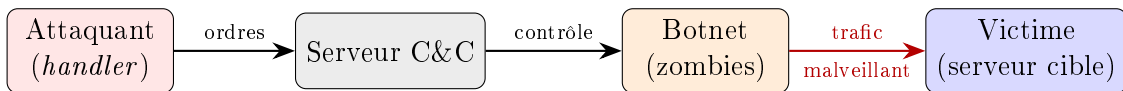


FIGURE 1.1 – Architecture générale d’une attaque DDoS.

Specht et Lee [23] soulignent que la compromission de milliers voire de millions de machines forme des botnets dont la puissance agrégée dépasse largement la capacité de réponse d’un seul nœud de défense, justifiant ainsi l’intérêt d’une défense distribuée et collaborative.

1.2.3 Classification des attaques DDoS

La littérature propose plusieurs taxonomies des attaques DDoS [12], [28]. Nous adoptons ici la classification en trois grandes catégories, largement répandue dans les travaux académiques et industriels. Le Tableau 1.1 en offre une synthèse comparative.

1.2.3.1 Attaques volumétriques

Ces attaques visent à saturer la bande passante du lien réseau de la victime ou de son Fournisseur d’Accès Internet (FAI). Elles constituent la catégorie la plus répandue et la plus facile à générer avec un botnet. On distingue notamment :

- **UDP Flood** : envoi massif de paquets UDP vers des ports aléatoires de la cible. L’effet principal réside dans la saturation de la bande passante par le volume brut du trafic entrant [12].
- **ICMP Flood (*Ping Flood*)** : saturation par des requêtes ICMP Echo Request en volume.
- **Attaques par amplification/réflexion** : exploitation de serveurs tiers (DNS, NTP, memcached) pour amplifier le volume du trafic. L’attaquant envoie des requêtes à adresse source *spoofée* (celle de la victime) vers des serveurs ouverts, qui répondent avec des paquets de taille bien supérieure. Selon Rossow [20], le facteur d’amplification DNS peut atteindre $28\times$ à $54\times$, et celui de NTP jusqu’à $556\times$. Les attaques via memcached ont démontré des facteurs dépassant $50\,000\times$ [1].

1.2.3.2 Attaques sur les protocoles réseau

Ces attaques exploitent des faiblesses dans les protocoles de communication (TCP, ICMP) pour épuiser les ressources de traitement des équipements réseau intermédiaires.

- **SYN Flood** : exploitation du mécanisme de *handshake* TCP en trois voies. L’attaquant envoie des paquets SYN avec adresses source *spoofées*, forçant le serveur à maintenir en mémoire des connexions semi-ouvertes jusqu’à épuisement de la table d’état (*backlog*). Eddy [4] décrit en détail les vulnérabilités du protocole TCP exploitées par ce type d’attaque.
- **Smurf Attack** : envoi de requêtes ICMP *broadcast* avec adresse source *spoofée* (celle de la victime), générant une avalanche de réponses vers la cible.

Note historique : Le *Ping of Death*, qui consistait à envoyer des paquets ICMP de taille supérieure au maximum autorisé, a constitué une menace dans les années 1990 mais est aujourd’hui corrigé.

1.2.3.3 Attaques applicatives (couche 7)

Ces attaques ciblent la couche application du modèle OSI et sont particulièrement difficiles à distinguer du trafic légitime, car elles utilisent des requêtes HTTP, HTTPS, DNS valides du point de vue syntaxique [28].

- **HTTP Flood** : envoi massif de requêtes HTTP GET ou POST vers un serveur web, saturant sa capacité de traitement sans nécessiter un volume de trafic important.
- **Slowloris** : maintien d’un maximum de connexions HTTP ouvertes vers le serveur cible en envoyant des en-têtes partiels à faible débit, empêchant le serveur d’accepter de nouvelles connexions légitimes.
- **DNS Query Flood** : envoi massif de requêtes DNS valides pour épuiser les ressources des serveurs de noms.

TABLE 1.1 – Synthèse comparative des catégories d’attaques DDoS.

Caractéristique	Volumétrique	Protocole	Applicative (L7)
Couche OSI ciblée	3–4 (Réseau /Transport)	3–4 (Réseau /Transport)	7 (Application)
Objectif principal	Saturer la bande passante	Épuiser les tables d’état	Épuiser les ressources applicatives
Volume requis	Très élevé (Gbps–Tbps)	Modéré	Faible à modéré
Difficulté de détection	Faible (anomalie volumétrique)	Moyenne	Élevée (trafic légitime en apparence)
Exemples	UDP Flood, Amplification	SYN Flood, Smurf	HTTP Flood, Slowloris
Mitigation typique	Filtrage, <i>blackholing</i>	SYN cookies, <i>rate limiting</i>	Analyse comportementale, WAF

1.2.4 Impact et données statistiques

Les attaques DDoS engendrent des pertes économiques considérables. Selon le rapport NETSCOUT Threat Intelligence Report 2023, plus de 7,9 millions d’attaques DDoS ont été enregistrées sur la seule première moitié de l’année 2023, soit une moyenne de plus de 44 000 attaques par jour [16]. Zargar et al. [28] estiment que le coût moyen d’une

attaque DDoS pour une entreprise peut dépasser 50 000 dollars par heure d'interruption de service, incluant les pertes commerciales directes, les coûts de mitigation et les dommages réputationnels.

1.3 Infrastructure de mitigation DDoS

La mitigation des attaques DDoS repose sur un ensemble d'infrastructures et de techniques déployées à différents niveaux du réseau. Cette section présente les principales solutions existantes, leurs mécanismes de fonctionnement et leurs limites respectives.

1.3.1 Les *scrubbing centers* : définition et rôle

Un *scrubbing center* (ou centre de nettoyage du trafic) est une infrastructure spécialisée dont la mission est d'analyser le trafic réseau entrant, de filtrer les paquets malveillants, puis de renvoyer uniquement le trafic légitime vers la destination finale. Ce mécanisme est souvent désigné sous le terme de « *clean pipe* » [9].

Le processus de mitigation via *scrubbing center* se déroule en plusieurs étapes distinctes (voir Figure 1.2) :

1. **Détection** : une anomalie dans le trafic déclenche une alerte (analyse NetFlow/sFlow, seuils de bande passante, corrélation multi-sources).
2. **Redirection** : le trafic destiné à la victime est redirigé vers le *scrubbing center* via des mécanismes de routage (Border Gateway Protocol (BGP), DNS).
3. **Analyse et filtrage** : le centre analyse le trafic en appliquant un pipeline de traitement multi-couches (empreintes, comportement, limitation de débit).
4. **Réinjection** : le trafic nettoyé est retransmis à la victime via un tunnel Generic Routing Encapsulation (GRE) ou MPLS pour éviter les boucles de routage.

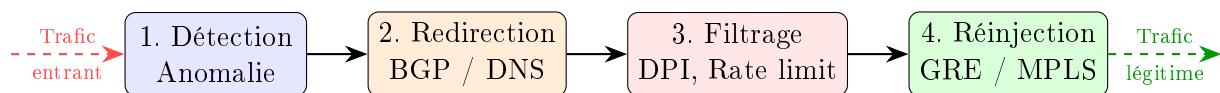


FIGURE 1.2 – Processus de mitigation via un *scrubbing center*.

Parmi les principaux fournisseurs de *scrubbing centers*, on trouve des acteurs comme Arbor Networks (Sightline/TMS), Akamai (Prolexic), Radware (DefensePro) et A10 Networks (Thunder TPS). Ces solutions offrent des capacités de traitement allant de quelques dizaines de Gbps à plusieurs Tbps selon l'infrastructure déployée.

1.3.2 Les réseaux de diffusion de contenu (CDN) comme bouclier anti-DDoS

Les **CDN** (*Content Delivery Networks*) tels que Cloudflare, Akamai et AWS CloudFront constituent une autre ligne de défense majeure contre les attaques DDoS. Leur principe repose sur la **distribution géographique** du contenu et du traitement du trafic à travers un réseau mondial de points de présence (PoP).

Le mécanisme de protection d'un CDN fonctionne comme suit :

1. **Interception par DNS** : les enregistrements DNS de la victime sont modifiés pour pointer vers les serveurs du CDN. Tout le trafic entrant transite donc par le réseau du CDN avant d'atteindre le serveur d'origine.
2. **Absorption volumétrique** : grâce à la technique **Anycast**, le même préfixe IP est annoncé depuis des centaines de PoP répartis mondialement. Le trafic est automatiquement dirigé vers le PoP le plus proche géographiquement, ce qui **distribue naturellement** la charge d'une attaque volumétrique sur l'ensemble du réseau.
3. **Filtrage en bordure** : chaque PoP applique des règles de filtrage (limitation de débit, WAF, challenges JavaScript/CAPTCHA) pour bloquer le trafic malveillant avant qu'il n'atteigne le serveur d'origine.
4. **Transmission du trafic légitime** : seul le trafic validé est transmis au serveur d'origine via un canal sécurisé (HTTPS).

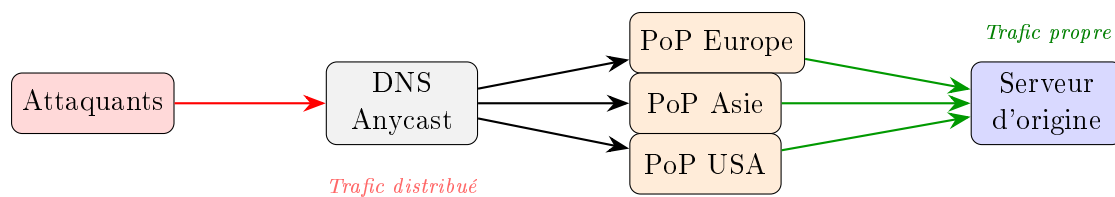


FIGURE 1.3 – Principe de protection anti-DDoS par un CDN avec Anycast.

Cependant, les CDN présentent des limites :

- **Protection limitée à la couche applicative (HTTP/HTTPS)** : les CDN protègent principalement les services web. Les attaques ciblant d'autres protocoles (DNS autoritaire, VoIP, jeux en ligne, VPN) ne bénéficient pas de cette protection.
- **Dépendance à un fournisseur tiers** : l'ensemble du trafic transite par l'infrastructure du CDN, créant une dépendance forte et un risque de confidentialité.
- **Coûts variables** : la tarification au volume peut devenir prohibitive lors d'attaques massives prolongées.

1.3.3 Les pare-feu et systèmes de prévention d'intrusion (IPS)

Les **pare-feu** (*firewalls*) et les **systèmes de prévention d'intrusion** (*Intrusion Prevention Systems* — IPS) constituent la première ligne de défense déployée en périphérie du réseau de l'organisation.

1.3.3.1 Pare-feu traditionnels et nouvelle génération (NGFW)

Les pare-feu filtrent le trafic réseau en fonction de règles prédéfinies basées sur les adresses IP, les ports et les protocoles. Les **pare-feu de nouvelle génération** (NGFW — *Next-Generation Firewall*) ajoutent des capacités d'inspection applicative :

- **Inspection à états (*stateful inspection*)** : suivi des connexions TCP pour détecter les anomalies (SYN Flood, connexions incomplètes).
- **Inspection applicative (couche 7)** : analyse du contenu des paquets pour identifier les requêtes malveillantes (injections SQL, requêtes HTTP anormales).
- **Limitation de débit (*rate limiting*)** : restriction du nombre de connexions par source IP et par unité de temps.

1.3.3.2 Systèmes de prévention d'intrusion (IPS)

Les IPS analysent le trafic en temps réel pour détecter et bloquer les comportements malveillants en se basant sur :

- **Signatures** : correspondance avec une base de signatures d'attaques connues (similaire aux antivirus).
- **Anomalies** : détection de déviations par rapport à un profil de trafic normal (*baseline*).
- **Heuristiques** : analyse comportementale combinant plusieurs indicateurs pour détecter des attaques inconnues (*zero-day*).

Limites face aux attaques DDoS : les pare-feu et IPS sont dimensionnés pour le volume de trafic *normal* de l'organisation. Lors d'une attaque volumétrique, le pare-feu lui-même devient un goulot d'étranglement : sa capacité de traitement (mesurée en paquets par seconde — pps) est rapidement dépassée, ce qui peut provoquer l'effondrement de l'ensemble du périmètre de sécurité. De plus, les pare-feu à états consomment de la mémoire pour chaque connexion suivie, les rendant particulièrement vulnérables aux attaques d'épuisement de tables d'état (SYN Flood, TCP connection exhaustion).

1.3.4 Le *blackholing* et le RTBH (*Remote Triggered Black Hole*)

Le *blackholing* est une technique de dernier recours qui consiste à rediriger l'intégralité du trafic destiné à une adresse IP attaquée vers une route nulle (`null0` / *bit bucket*), supprimant ainsi tout le trafic — légitime et malveillant — vers cette destination.

Le mécanisme **RTBH** (*Remote Triggered Black Hole*, RFC 5635 [8]) permet d'automatiser ce processus via BGP :

1. Le réseau victime annonce le préfixe attaqué avec une **communauté BGP spéciale** (ex. : `AS:666`) à ses fournisseurs de transit.
2. Les routeurs des fournisseurs de transit, configurés pour reconnaître cette communauté, redirigent le trafic vers `null0`.
3. Le trafic d'attaque est ainsi éliminé *en amont*, avant qu'il ne sature les liens du réseau victime.

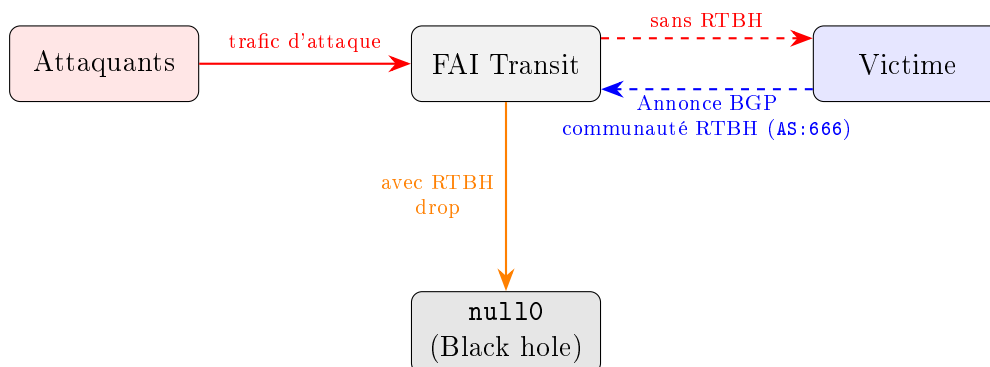


FIGURE 1.4 – Mécanisme de RTBH via BGP : la victime annonce un préfixe avec une communauté RTBH, et le FAI redirige le trafic correspondant vers `null0`.

Avantage : le *blackholing* est extrêmement efficace pour protéger l'infrastructure réseau (les liens ne sont plus saturés).

Inconvénient majeur : il constitue une **victoire de l'attaquant**. En supprimant tout le trafic vers la cible — y compris le trafic légitime —, le *blackholing* produit exactement le résultat recherché par l'attaque : le déni de service. C'est pourquoi cette technique n'est utilisée qu'en dernier recours, lorsque le sacrifice d'un service est préférable à l'effondrement de l'infrastructure complète.

1.3.5 Les services de mitigation cloud (*Cloud-based DDoS Protection*)

Les **services de mitigation cloud** sont proposés par des fournisseurs spécialisés (Cloudflare, AWS Shield, Azure DDoS Protection, Google Cloud Armor) qui disposent d'une infrastructure mondiale massive pour absorber les attaques DDoS.

Le fonctionnement repose sur le même principe que les *scrubbing centers*, mais avec deux différences majeures :

- **Capacité élastique** : les fournisseurs cloud disposent de capacités de traitement pouvant dépasser 100 Tbps en cumulé sur l'ensemble de leurs PoP, ce qui leur permet d'absorber les attaques les plus volumétriques.
- **Modèle *as-a-Service*** : la mitigation est proposée sous forme d'abonnement, évitant à l'organisation d'investir dans une infrastructure physique dédiée.

Le Tableau 1.2 compare les principaux services de mitigation cloud disponibles sur le marché.

TABLE 1.2 – Comparaison des principaux services de mitigation cloud.

Service	Capacité	Couches protégées	Activation
Cloudflare	348 Tbps (réseau global)	L3/L4 + L7 (WAF intégré)	Always-on (automatique)
AWS Shield Advanced	Élastique (infra AWS)	L3/L4 + L7 (avec WAF)	Always-on + sur demande
Azure DDoS Protection	Élastique (infra Azure)	L3/L4	Always-on
Google Cloud Armor	Élastique (infra Google)	L7 (HTTP/HTTPS)	Always-on
Akamai Prolexic	20+ Tbps (scrubbing dédié)	L3/L4 + L7	On-demand (BGP redirect)

Limites des services cloud :

- **Dépendance au fournisseur** : l'organisation confie l'intégralité de son trafic à un tiers, ce qui soulève des questions de confidentialité, de souveraineté des données et de *vendor lock-in*.
- **Coûts récurrents** : les abonnements premium (ex. : AWS Shield Advanced à 3 000 \$/mois + coûts de transfert de données) peuvent être prohibitifs pour les petites structures.
- **Latence additionnelle** : le reroutage du trafic via le réseau du fournisseur ajoute une latence (typiquement 5 à 30 ms selon la distance au PoP le plus proche).

- **Absence de coordination inter-fournisseurs** : chaque service opère de manière isolée. Il n'existe pas de mécanisme standardisé pour que Cloudflare, AWS et Akamai coordonnent leurs actions face à une attaque ciblant simultanément plusieurs de leurs clients.

1.3.6 Techniques de redirection du trafic

La redirection du trafic vers une infrastructure de mitigation (qu'il s'agisse d'un *scrubbing center*, d'un CDN ou d'un service cloud) est une opération critique. Plusieurs techniques sont utilisées en pratique :

- **BGP Blackholing et BGP Flowspec** : Le protocole BGP (RFC 4271 [18]) permet d'annoncer des préfixes IP pour rediriger le trafic. Le BGP Flowspec (RFC 5575 [10]) étend cette capacité en distribuant des règles de filtrage fin (correspondance sur les champs source/destination IP, port, protocole, taille de paquet, fragment) sous forme de Network Layer Reachability Information (NLRI) multi-champs, permettant aux routeurs de bordure d'appliquer des actions (**discard**, **rate-limit**, **redirect** vers VRF) sans intervention manuelle.
- **DNS Redirection** : Modification des enregistrements DNS de la victime pour pointer vers l'infrastructure de mitigation. Technique utilisée par les CDN (Cloudflare, Akamai) et les services cloud.
- **Anycast** : Déploiement du même préfixe IP sur plusieurs nœuds distribués géographiquement, permettant une absorption distribuée naturelle. Le trafic est dirigé vers le nœud le plus proche selon la topologie BGP.
- **Tunnel GRE/MPLS** : Encapsulation du trafic nettoyé pour le renvoyer à la victime via un chemin distinct (*clean-return path*), évitant les boucles de routage.

1.3.7 Synthèse et comparaison des infrastructures de mitigation

Le Tableau 1.3 compare les différentes infrastructures de mitigation présentées dans cette section selon plusieurs critères clés.

TABLE 1.3 – Comparaison des infrastructures de mitigation DDoS.

Solution	Couches	Capacité	Avantage principal	Limite principale
Scrubbing center	L3/L4/L7	Élevée (Tbps)	Filtrage fin multi-couches	Coût, latence de redirection
CDN (Anycast)	L7 (HTTP)	Très élevée	Distribution géographique	Limité au trafic web
Pare-feu / IPS	L3/L4/L7	Limitée (Gbps)	Proximité, contrôle local	Goulot d'étranglement
RTBH Blackholing	L3	Illimitée	Protège l'infrastructure	Supprime le trafic légitime
Service cloud	L3/L4/L7	Élastique	Capacité massive, as-a-Service	Dépendance, coût, confidentialité

1.3.8 Limites des approches centralisées

Bien que les solutions présentées ci-dessus offrent chacune des capacités de mitigation significatives, elles partagent un trait commun : elles opèrent de manière **centralisée et isolée**. Chaque organisation déploie ses propres défenses ou souscrit à un service individuel, sans mécanisme de coordination avec les autres entités potentiellement touchées par la même attaque.

Cette approche présente plusieurs limites fondamentales [3] :

- **Point de défaillance unique (SPOF)** : que ce soit le *scrubbing center*, le contrôleur SDN ou le fournisseur cloud, toute architecture centralisée introduit un point critique dont la défaillance compromet l'ensemble de la protection.
- **Latence de redirection** : le reroutage du trafic vers une infrastructure distante introduit une latence additionnelle (10 à 50 ms) qui dégrade la qualité de service pour les applications sensibles (VoIP, jeux en ligne, trading haute fréquence).
- **Capacité finie** : même les plus grandes infrastructures ont une capacité maximale. Face à une attaque dépassant cette capacité, la solution centralisée est elle-même submergée.
- **Visibilité locale** : chaque solution n'observe que le trafic qui lui est redirigé. Elle ne peut pas corréler ses observations avec celles d'autres infrastructures pour détecter des attaques coordonnées ciblant simultanément plusieurs victimes.
- **Absence de mutualisation** : les ressources de mitigation de différentes organisations ne sont pas partagées. Un *scrubbing center* sous-utilisé ne peut pas venir en aide à un voisin surchargé.
- **Coûts prohibitifs** : le dimensionnement d'une infrastructure capable d'absorber les attaques les plus volumétriques (multi-Tbps) représente un investissement considérable, inaccessible aux PME et aux petites collectivités.

Ces limitations convergent vers un constat : **la défense isolée ne suffit plus**. La réponse aux attaques DDoS modernes nécessite une approche **collaborative et distribuée**, où plusieurs entités autonomes coordonnent leurs actions en temps réel pour mutualiser leurs capacités de détection, d'analyse et de filtrage. C'est cette approche que nous développons dans ce mémoire.

1.4 Architecture pair-à-pair pour la coordination inter-nœuds

1.4.1 Définition et pertinence du modèle pair-à-pair

Une architecture P2P est un modèle de système distribué dans lequel les nœuds (ou pairs) sont logiquement équivalents et peuvent assumer simultanément les rôles de client et de serveur. Contrairement aux architectures centralisées traditionnelles, aucun nœud ne joue le rôle d'autorité de contrôle unique [26]. Chaque pair peut ainsi fournir des services aux autres tout en consommant leurs ressources.

Dans le contexte de la mitigation des attaques DDoS, ce modèle apparaît particulièrement pertinent pour répondre aux limites des architectures centralisées identifiées précédemment (cf. section 1.3.8). En structurant différents mécanismes de défense — tels que les *scrubbing centers*, les pare-feu ou les systèmes de détection — au sein d'un réseau logique superposé (*overlay network*), l'architecture P2P permet de répartir les capacités de détection et de filtrage entre plusieurs entités autonomes.

Une telle organisation repose sur trois principes fondamentaux :

- **Décentralisation** : l'absence de point de contrôle central élimine les points de défaillance uniques (SPOF) et renforce la résilience globale de l'infrastructure de défense.
- **Autonomie et coopération** : chaque nœud conserve la maîtrise de ses ressources locales tout en participant à un mécanisme de défense collectif, permettant de mutualiser les capacités de détection et de mitigation.
- **Symétrie des rôles** : un même pair peut signaler une attaque lorsqu'il est victime et contribuer simultanément à la mitigation en appliquant des règles de filtrage ou en relayant des informations vers d'autres pairs.

Cette approche ouvre la voie à des mécanismes de défense collaborative où plusieurs organisations peuvent coordonner leurs actions afin de limiter l'impact d'attaques distribuées à grande échelle.

1.4.2 Topologies et protocoles P2P applicables à la mitigation

Les systèmes P2P peuvent adopter différentes formes d'organisation, dont l'efficacité varie selon les objectifs et les contraintes du système distribué [26]. Dans le cadre d'une infrastructure de défense collaborative, plusieurs modèles sont particulièrement pertinents.

- **P2P non structuré** : Dans ce modèle, les nœuds établissent des connexions de manière ad hoc sans structure globale prédéfinie. La recherche d'information ou la diffusion d'alertes s'effectue généralement par inondation (*flooding*). Bien que cette approche soit très robuste face à la disparition de pairs, elle entraîne une surcharge réseau importante et devient difficilement scalable dans des environnements comportant un grand nombre de participants.
- **P2P structuré (Distributed Hash Table (DHT))** : Les architectures structurées reposent sur une topologie logique déterministe, souvent implémentée à l'aide d'une table de hachage distribuée (DHT). Des systèmes tels que Chord [24] permettent de localiser une information en $O(\log N)$ sauts. Dans le contexte de la défense DDoS, une DHT peut être utilisée pour maintenir une base de données distribuée contenant des indicateurs de compromission, des signatures d'attaques ou des listes d'adresses IP malveillantes partagées entre participants.
- **P2P hybride** : Les architectures hybrides introduisent la notion de *super-pairs*. Certains nœuds disposant de capacités importantes (par exemple des *scrubbing centers* ou des nœuds cœur de réseau d'un FAI) jouent un rôle de coordination ou d'agrégation, tandis que des nœuds périphériques participent à l'échange d'informations avec des capacités plus limitées. Ce modèle permet d'améliorer l'efficacité du routage des messages tout en conservant un degré de décentralisation.
- **Protocoles épidémiques (*gossip*)** : Les protocoles *gossip* reposent sur une diffusion probabiliste de l'information. Chaque nœud transmet périodiquement son état ou une alerte à un sous-ensemble aléatoire de ses voisins. Cette approche offre une forte tolérance aux pannes et permet une propagation rapide des informations, généralement en $O(\log N)$ cycles de communication. Dans le cadre d'une défense collaborative, les mécanismes *gossip* sont particulièrement adaptés pour diffuser rapidement des alertes d'attaque ou des règles de mitigation sans saturer le réseau de communication.

1.4.3 Défis du P2P appliqué à la sécurité réseau

Malgré ses avantages, l'application d'un modèle distribué à la coordination d'infrastructures de défense appartenant à des entités indépendantes soulève plusieurs défis majeurs.

- **Gestion de la confiance** : Dans un système décentralisé, l'absence d'autorité centrale complique la validation de l'identité et de la fiabilité des pairs. Un nœud compromis pourrait diffuser de fausses alertes afin de provoquer un blocage injustifié du trafic légitime (*blackholing* offensif) ou créer de multiples identités afin d'influencer les décisions collectives (attaque *Sybil*). La mise en place de mécanismes d'authentification forte ou de systèmes de réputation devient alors indispensable.
- **Latence de convergence** : Les attaques DDoS volumétriques peuvent saturer les ressources d'une cible en quelques secondes. La propagation des alertes et la synchronisation des mécanismes de filtrage entre pairs doivent donc être extrêmement rapides afin que la mitigation distribuée puisse être effective avant l'effondrement du service attaqué.
- **Problème du passager clandestin (*free-rider*)** : La mitigation d'attaques distribuées nécessite des ressources importantes en bande passante et en capacité de traitement. Dans un système coopératif ouvert, certains participants pourraient bénéficier de la protection collective sans contribuer réellement à l'effort de mitigation. Des mécanismes d'incitation à la coopération, tels que des quotas de contribution ou des systèmes de réputation, peuvent être nécessaires pour limiter ce comportement.
- **Passage à l'échelle sous contrainte réseau** : Lors d'une attaque de grande ampleur, le plan de données du réseau peut subir une congestion importante. Le réseau de coordination P2P — qui constitue le plan de contrôle du système — doit donc rester opérationnel même en présence de pertes de paquets élevées ou de fortes variations de latence.

Ces défis expliquent pourquoi la mise en œuvre de mécanismes de défense véritablement distribués reste complexe dans la pratique. Les approches existantes tentant d'exploiter ces principes seront analysées dans le chapitre suivant à travers l'étude de plusieurs systèmes représentatifs de la littérature.

1.5 Conclusion

Ce chapitre a posé les fondements nécessaires à la compréhension du travail présenté dans ce mémoire. Nous avons défini les attaques DDoS et leurs catégories (volumétriques, protocolaires, applicatives), décrit l'infrastructure de mitigation actuelle (*scrubbing centers*) et ses limites centralisées, puis introduit l'architecture P2P comme solution potentielle de coordination entre nœuds de défense.

Le chapitre suivant analyse les principales approches existantes en matière de défense collaborative contre les attaques DDoS.

Chapitre 2

Étude bibliographique

2.1 Introduction

La défense collaborative contre les attaques DDoS a donné lieu à une littérature académique riche ainsi qu'à plusieurs déploiements institutionnels et industriels. Ce chapitre analyse quatre contributions majeures, sélectionnées pour leur représentativité des différentes approches existantes :

- un standard de signalisation inter-domaines (DOTS),
- une coalition nationale de partage de métadonnées (DDoS Clearing House),
- une mutualisation opérationnelle de *scrubbing centers* (NaWas/NBIP),
- un overlay coopératif distribué (DefCOM).

Pour chaque travail, nous décrivons le contexte de sa conception, son architecture technique détaillée, ses mécanismes protocolaires et ses limites identifiées. Une synthèse comparative clôt le chapitre et identifie les lacunes que notre contribution vise à combler.

2.2 DOTS — DDoS Open Threat Signaling

2.2.1 Contexte et motivation

L'IETF a initié le groupe de travail DOTS (*DDoS Open Threat Signaling*) pour définir un protocole standardisé permettant à une entité attaquée de notifier automatiquement un prestataire de mitigation. Les exigences sont formalisées dans la RFC 8612 [14] et le canal de signalisation dans la RFC 8782 [17].

2.2.2 Architecture et fonctionnement

DOTS repose sur une architecture client–serveur asymétrique comprenant un **DOTS client** (l'entité sous attaque) et un **DOTS server** (le prestataire de mitigation).

Le protocole s'appuie sur une pile technologique légère adaptée aux environnements contraints et congestionnés, divisée en deux canaux distincts (voir Figure 2.1) :

2.2.2.1 Canal de signalisation (*Signal Channel*)

Ce canal utilise le protocole Constrained Application Protocol (CoAP) (*Constrained Application Protocol*, RFC 7252) sécurisé par Datagram Transport Layer Security (DTLS) 1.2 (RFC 6347) sur UDP. Ce choix est stratégique : contrairement à TCP, UDP

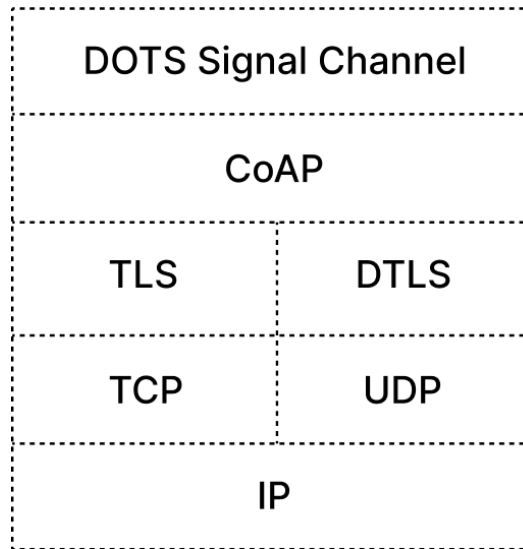


FIGURE 2.1 – Architecture de référence du protocole DOTS : séparation entre le canal de signalisation (CoAP/DTLS/UDP) et le canal de données (RESTCONF/HTTPS/TCP).

évite les délais de retransmission et le blocage de tête de ligne (*Head-of-Line blocking*) fréquents lors d’une saturation de lien.

Concrètement, le client émet une requête CoAP PUT sur l’URI :

`/dots/signal/{cuid}/{mid}`

contenant un objet Concise Binary Object Representation (CBOR) (*Concise Binary Object Representation*, RFC 8949) qui spécifie :

- les préfixes IP à protéger (**target-prefix**),
- les numéros de port (**target-port-range**),
- le protocole (**target-protocol**),
- la durée de mitigation souhaitée (**lifetime**).

Le serveur répond avec un code 2.01 **Created** et un identifiant de mitigation (**mid**).

Ce canal gère le cycle de vie de la mitigation via une **machine à états à quatre transitions** :

idle $\longrightarrow$ *mitigation-requested* $\longrightarrow$ *attack-mitigation-in-progress* $\longrightarrow$ *terminated*

Un mécanisme de *heartbeat* (messages CoAP GET périodiques, intervalle configurable via **heartbeat-interval**) vérifie la connectivité entre client et serveur. En l’absence de réponse après un nombre configurable de tentatives (**missing-hb-allowed**), le client déclenche une procédure de reprise (*failover*).

2.2.2.2 Canal de données (*Data Channel*)

Basé sur **RESTCONF** (RFC 8040) via HTTPS (TLS 1.2+, TCP), il permet l’échange de configurations complexes et moins urgentes. Les données sont modélisées en YANG (RFC 7950). Ce canal sert à :

- Définir des **alias** (*dots-alias*) regroupant plusieurs préfixes IP, ports et protocoles sous un identifiant unique, réduisant la taille des messages de signalisation en période d’attaque.

- Pré-configurer des **Access Control Lists (ACLs)** en amont, modélisées selon le module YANG `ietf-dots-data-channel` (RFC 8783). Ces ACLs spécifient des règles de filtrage au format `ietf-access-control-list` incluant les critères de correspondance (5-tuple : IP source/destination, port source/destination, protocole) et les actions (`permit`, `deny`, `rate-limit`).
- Récupérer les **télémétries** d'attaque (RFC 9244) : bande passante entrante, nombre de paquets par seconde, distribution des protocoles d'attaque, *top talkers* (sources les plus actives).

2.2.3 Limites identifiées

- **Modèle hiérarchique strict** : DOTS est fondamentalement asymétrique (client → serveur). Il ne prévoit pas de coordination **horizontale** entre clients — un client DOTS ne peut pas signaler une attaque à un *pair* DOTS ni partager des métadonnées d'attaque avec d'autres victimes potentielles. Le protocole ne définit pas de mécanisme de *peering* entre serveurs DOTS de différents opérateurs.
- **Absence de mutualisation de capacité** : DOTS signale le *besoin* de mitigation mais ne spécifie pas comment répartir la charge entre plusieurs mitigeurs. Si le serveur DOTS est lui-même saturé, aucun mécanisme de délégation ou d'équilibrage n'est prévu par le standard.
- **Confiance limitée aux relations bilatérales** : L'authentification repose sur des certificats X.509 ou PSK (*Pre-Shared Key*) pré-provisionnés. Il n'existe pas de mécanisme dynamique pour évaluer la fiabilité d'un pair inconnu [14], ce qui limite le déploiement à des relations contractuelles préétablies.
- **Pas de partage d'intelligence** : DOTS transmet des *demandes* de mitigation, non des *signatures* d'attaque. Un serveur DOTS ne redistribue pas les caractéristiques techniques de l'attaque (vecteurs, TTL, taille de paquets) aux autres entités du réseau pour une protection proactive.

2.3 DDoS Clearing House — Partage collaboratif de *fingerprints*

2.3.1 Contexte et motivation

Le projet DDoS Clearing House, développé par SIDN Labs dans le cadre du projet européen CONCORDIA (H2020), vise à briser le cloisonnement des informations sur les attaques DDoS entre opérateurs. Il permet le partage automatisé de *fingerprints* (empreintes) d'attaques entre membres d'une coalition nationale [22].

2.3.2 Architecture et fonctionnement

2.3.2.1 Le *DDoS Fingerprint* : structure et contenu

Le cœur du système repose sur le **DDoS Fingerprint**, une structure de données standardisée décrivant les caractéristiques techniques observées d'une attaque, *sans inclure de données personnelles identifiables* (PII). Chaque fingerprint contient :

- **Vecteur d'attaque** : type identifié (ex. : `DNS_AMPLIFICATION`, `NTP_AMPLIFICATION`, `SYN_FLOOD`, `UDP_FLOOD`).

- **Caractéristiques réseau** : protocole de transport (TCP/UDP/ICMP), port(s) source et destination observés, préfixes source agrégés (anonymisés en /24 ou /16 pour préserver la vie privée).
- **Caractéristiques des paquets** : taille moyenne et distribution des paquets, valeur TTL observée (indicateur de distance réseau des sources), flags TCP (pour les SYN floods), présence ou absence de fragmentation IP.
- **Métriques volumétriques** : débit crête observé (pps et bps), durée de l'attaque, nombre estimé de sources uniques.
- **Horodatage** : timestamp UTC de début et fin de l'attaque.

Les fingerprints sont sérialisés au format **JSON** et échangés via une **API REST** (HTTPS) entre les composants du système.

2.3.2.2 Architecture logicielle

Le système suit une architecture à trois composants (voir Figure 2.2) :

1. **Module local de génération (*DDoS DB local*)** : Déployé chez chaque membre participant, ce module se connecte aux outils de détection existants (NetFlow/IPFIX collectors, IDS type Suricata/Snort, ou plateformes DDoS dédiées). Il capture les métadonnées du trafic d'attaque via **DissecTor**, un outil d'analyse de captures PCAP développé par SIDN Labs, qui extrait automatiquement les champs du fingerprint à partir du trafic brut. Le module applique ensuite une **anonymisation** des adresses IP sources (troncature à /24) et supprime tout payload applicatif avant transmission.
2. **Clearing House central (*Hub*)** : Un serveur central reçoit les fingerprints via l'API REST, les **déduplique** (en identifiant les attaques observées par plusieurs membres simultanément grâce à la corrélation temporelle et aux vecteurs communs), les **enrichit** (ajout de métadonnées de réputation des préfixes sources via des bases comme Shodan ou Spamhaus) et les stocke dans une base de données centralisée. Le hub expose une API de consultation permettant aux membres d'interroger l'historique par vecteur d'attaque, période ou préfixe cible.
3. **Module de consommation (*Converter*)** : Chaque membre récupère les fingerprints pertinents et un module de conversion les traduit automatiquement en **règles de filtrage** opérationnelles adaptées à l'infrastructure locale :
 - Règles **iptables/nftables** pour le filtrage Linux.
 - Règles **BGP Flowspec** (RFC 5575) pour distribution aux routeurs de bordure.
 - Politiques pour *scrubbing appliances* (ex. : Arbor Sightline/TMS, A10 Thunder TPS).

2.3.3 Limites identifiées

- **Partage passif sans orchestration** : Le système se limite au partage d'**intelligence** (*Threat Intel*) sans orchestrer de réponse active. Il n'y a pas de mécanisme pour qu'un membre demande une mitigation distribuée aux autres — chaque membre applique indépendamment les règles dérivées des fingerprints reçus.
- **Architecture centralisée (SPOF)** : Le hub central constitue un point de défaillance unique : s'il est indisponible (panne, attaque ciblée), la dissémination des fingerprints est interrompue. La déduplication et l'enrichissement dépendent entièrement de ce composant.

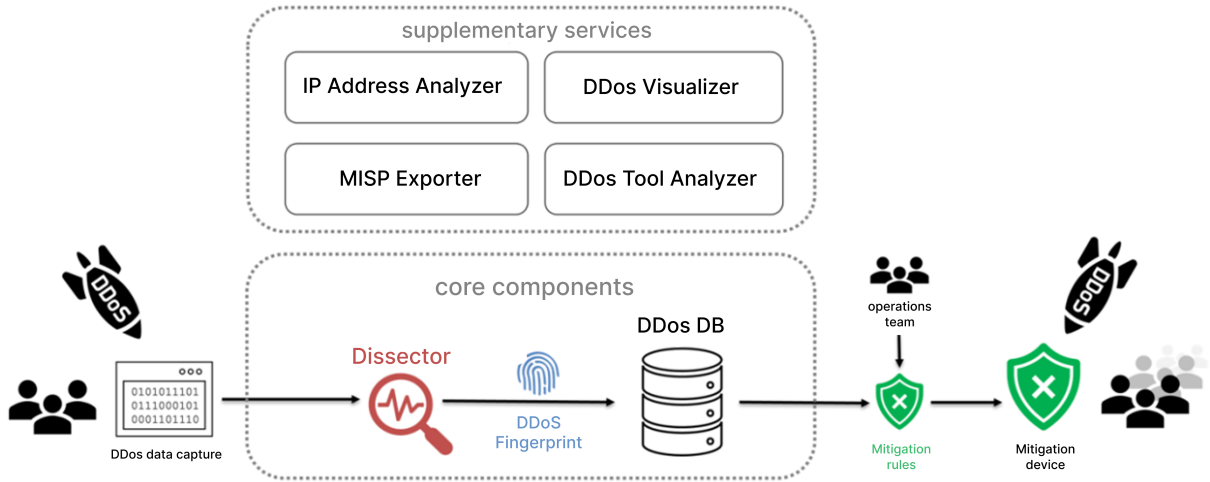


FIGURE 2.2 – Architecture du *DDoS Clearing House* : génération d’empreintes DDoS par le composant Dissector, stockage dans la base DDoS DB, puis utilisation par l’équipe opérationnelle pour générer des règles de mitigation.

- **Partage *a posteriori*** : La génération d’un fingerprint nécessite l’analyse du trafic d’attaque *après* sa détection. Le temps de traitement (capture PCAP → extraction DissecTor → upload API → déduplique → download par les membres → conversion en règles) introduit un **délai incompressible de l’ordre de plusieurs minutes** [22], rendant le système inefficace contre les attaques éphémères (*hit-and-run*, durée < 5 min).
- **Confiance implicite** : Le système ne définit pas de mécanisme formel de vérification de la véracité d’un fingerprint soumis. Un membre compromis ou malveillant pourrait théoriquement injecter de faux fingerprints pour provoquer le blocage de trafic légitime chez les autres membres (*poisoning attack*).

2.4 NaWas / NBIP — Centre national de *scrubbing* mutualisé

2.4.1 Contexte et architecture

NaWas (*National Wasstraat*, littéralement « station de lavage nationale ») est une initiative néerlandaise opérée par le NBIP (*Nationale Beheersorganisatie Internet Providers*), un consortium à but non lucratif regroupant des FAIs néerlandais. Elle offre une infrastructure de *scrubbing* mutualisée aux membres participants [15].

2.4.1.1 Mécanisme de redirection BGP

L’activation de la protection NaWas repose sur le principe de l’**injection de routes plus spécifiques** via BGP. En cas d’attaque (voir Figure 2.3) :

1. Le membre annonce le préfixe IP attaqué (ex. : 203.0.113.0/24) à la plateforme NaWas via une session eBGP dédiée, en y attachant une **communauté BGP spécifique** (ex. : AS:666 ou une communauté étendue propriétaire) qui indique la demande de scrubbing.

2. NaWas **réannonce** ce préfixe vers ses fournisseurs de transit (*upstream providers*) avec un *AS-path* plus court, attirant ainsi le trafic destiné au préfixe attaqué (*traffic attraction* par spécificité de préfixe).
3. Le trafic entrant est traité par des **scrubbing lanes** (lignes de nettoyage) composées d'appiances matérielles et logicielles qui appliquent :
 - Un **filtrage basé sur signatures** (Deep Packet Inspection (DPI)) pour les vecteurs d'attaque connus.
 - Un **rate limiting** adaptatif par source IP et par protocole.
 - Une **analyse comportementale** (détection d'anomalies statistiques sur la distribution des tailles de paquets, TTL, flags TCP).
 - Un **challenge cryptographique** (SYN cookies, JavaScript challenge pour HTTP) pour valider les connexions légitimes.
4. Le trafic nettoyé (*clean traffic*) est renvoyé au membre via un **tunnel GRE** (RFC 2784) ou un **VLAN dédié** sur une interconnexion privée, contournant ainsi la saturation des liens publics du membre. Le routage de retour utilise un chemin distinct (*clean-return path*) pour éviter les boucles de routage.

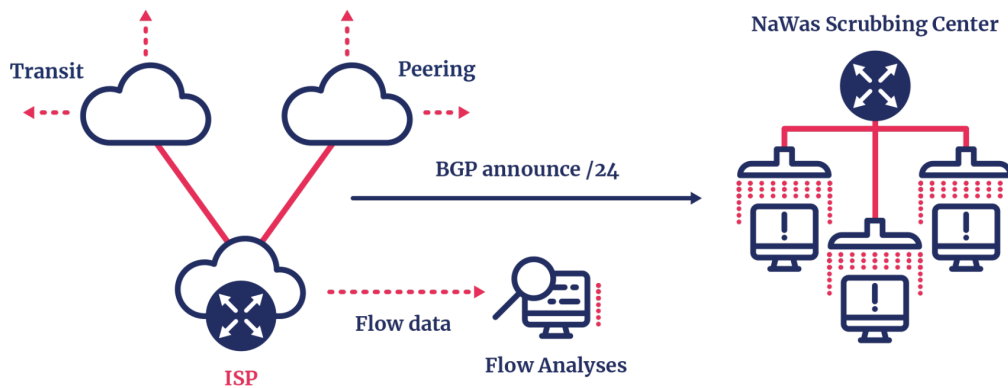


FIGURE 2.3 – Architecture simplifiée du service NaWas : redirection du trafic vers un centre de scrubbing mutualisé via annonce BGP et analyse des flux avant application des mécanismes de mitigation.

2.4.2 Limites identifiées

- **Architecture semi-centralisée** : Bien que mutualisée, l'infrastructure physique de NaWas est centralisée aux Pays-Bas (quelques PoP sur des IXP néerlandais — AMS-IX, NL-ix). Un membre éloigné géographiquement subit une latence de redirection significative. Le *scrubbing center* lui-même peut devenir un SPOF en cas d'attaque ciblant directement l'infrastructure NaWas.
- **Activation semi-manuelle** : L'injection de la route BGP avec la communauté de scrubbing nécessite typiquement une **intervention de l'opérateur** du membre (commande CLI sur le routeur de bordure ou via un portail web). Il n'y a pas de mécanisme de détection et d'activation entièrement automatisé intégré au protocole — l'automatisation dépend de l'intégration locale chez chaque membre.
- **Absence de coordination horizontale inter-membres** : Les membres NaWas n'échangent pas de métadonnées d'attaque entre eux ni ne coordonnent leurs actions de filtrage. Chaque membre interagit uniquement avec la plateforme centrale. Il n'y a pas de partage d'intelligence comparable au Clearing House.

- **Capacité finie** : La capacité totale de scrubbing est dimensionnée pour le volume agrégé moyen des attaques ciblant les membres. En cas d'attaque volumétrique massive (> 1 Tbps) ciblant un seul membre, la capacité mutualisée peut être insuffisante sans mécanisme de débordement (*overflow*) vers des tiers.

2.5 DefCOM — *Distributed Cooperative Overlay Defense*

2.5.1 Contexte et architecture

Proposé par Mirkovic et al. [11], DefCOM est un système de défense coopérative qui structure les nœuds de défense en un **réseau overlay logique** pour éviter les goulots d'étranglement centraux. C'est l'une des premières propositions académiques de défense DDoS véritablement distribuée.

2.5.1.1 Topologie et rôles des nœuds

DefCOM définit trois rôles fonctionnels pour les nœuds participants :

- **Nœuds *Victim-end* (V-nodes)** : Déployés dans le réseau de la victime, ils **dé-tectent** l'attaque en observant la surcharge locale (taux d'utilisation CPU, bande passante saturée, taux de paquets rejetés) et **initient** la réponse coopérative en classifiant les flux entrants comme légitimes (*good*) ou suspects (*bad*) à l'aide de statistiques locales et de listes blanches préétablies.
- **Nœuds *Core* (C-nodes)** : Positionnés dans les réseaux intermédiaires (FAIs de transit), ils relayent les informations de contrôle et appliquent le ***rate limiting*** sur les flux signalés comme suspects. Chaque C-node maintient un **classifieur de paquets** qui marque les paquets traversants via un champ de l'en-tête IP pour distinguer le trafic légitime du trafic suspect en aval.
- **Nœuds *Source-end* (S-nodes)** : Déployés au plus proche des sources d'attaque, ils appliquent le filtrage le plus agressif sur les flux identifiés comme malveillants, en utilisant les informations reçues des V-nodes et C-nodes. Leur objectif est de **supprimer le trafic d'attaque au plus tôt** dans le chemin réseau, préservant ainsi la bande passante des liens intermédiaires.

2.5.1.2 Mécanisme de *Rate Limiting* coopératif

L'architecture met en œuvre un mécanisme de ***Rate Limiting* coopératif hiérarchique** (voir Figure 2.4). Le protocole fonctionne comme suit :

1. Le V-node détecte une surcharge et calcule un **débit maximal acceptable** (R_{max}) pour le trafic entrant sur le préfixe attaqué.
2. Il envoie un message de type `RATE_LIMIT_REQUEST` à ses C-nodes voisins dans l'overlay, contenant : le préfixe cible, le débit maximal R_{max} , et une liste de préfixes sources classés comme suspects.
3. Chaque C-node recevant ce message **répartit** la limite de débit R_{max} proportionnellement entre ses liens amont :

$$R_i = R_{max} \times w_i \quad (2.1)$$

où w_i est le poids du lien i basé sur le volume de trafic observé, puis propage la demande vers les nœuds plus en amont.

4. Ce processus forme un **arbre de limitation de débit** (*rate-limiting tree*) où la contrainte se propage de la victime vers les sources, chaque nœud intermédiaire appliquant sa part du budget de débit.
5. Les S-nodes, en bout de chaîne, appliquent le **filtrage terminal** : les flux dépassant leur budget alloué R_i sont soit rejetés (*drop*), soit soumis à un marquage probabiliste (*probabilistic drop*) privilégiant les sources connues comme légitimes.

2.5.1.3 Protocole de communication overlay

La communication entre les nœuds se fait via un **protocole de type gossip** (épidémique). Chaque nœud maintient une **table de voisinage** (liste de pairs connus) et diffuse périodiquement ses informations d'état (charge actuelle, débit traité, alertes actives) à un sous-ensemble aléatoire de ses voisins. Ce mécanisme assure :

- Une **convergence rapide** : l'information atteint tous les nœuds en $O(\log N)$ rounds de gossip pour N participants.
- Une **tolérance aux pannes** : la perte d'un nœud intermédiaire n'empêche pas la propagation, grâce à la redondance des chemins de diffusion.

La construction de l'overlay suit un mécanisme de **découverte initiale par traceroute** : chaque nœud participant exécute des **traceroute** vers les autres nœuds connus pour reconstruire la topologie Internet sous-jacente et positionner correctement les C-nodes sur le chemin entre sources et victimes.

2.5.2 Limites identifiées

- **Contribution purement académique** : DefCOM est resté au stade de prototype évalué en simulation (ns-2). Aucun déploiement opérationnel à grande échelle n'a été documenté. Les évaluations publiées portent sur des topologies simulées de quelques dizaines de nœuds, loin des conditions réelles de l'Internet.
- **Absence de standards d'interopérabilité** : Le protocole de communication overlay (format des messages, encodage, machine à états) n'est défini que dans les publications académiques, sans spécification formelle (pas de RFC, pas de schéma YANG, pas d'API standardisée). Cela rend l'interopérabilité entre implémentations différentes impossible en pratique.
- **Vulnérabilité aux nœuds compromis** : Le modèle de confiance de DefCOM est **implicite** : tout nœud participant est considéré comme honnête. Un nœud compromis pourrait :
 - Générer de **fausses alertes** (RATE_LIMIT_REQUEST avec des préfixes légitimes comme cibles) pour provoquer le blocage de trafic légitime (*blackholing* offensif).
 - **Ignorer** les demandes de *rate limiting* reçues (*free-riding*).
 - **Manipuler** les poids de répartition pour rediriger le trafic légitime vers des liens saturés.

Aucun mécanisme de **réputation**, de **vérification cryptographique des messages**, ou de **détection de comportement byzantin** n'est intégré.

- **Hypothèse de déploiement incrémental** : DefCOM suppose un **déploiement coopératif** par des Autonomous Systems (ASs) multiples, incluant des FAIs de transit. En pratique, l'incitation économique pour un FAI de transit à déployer

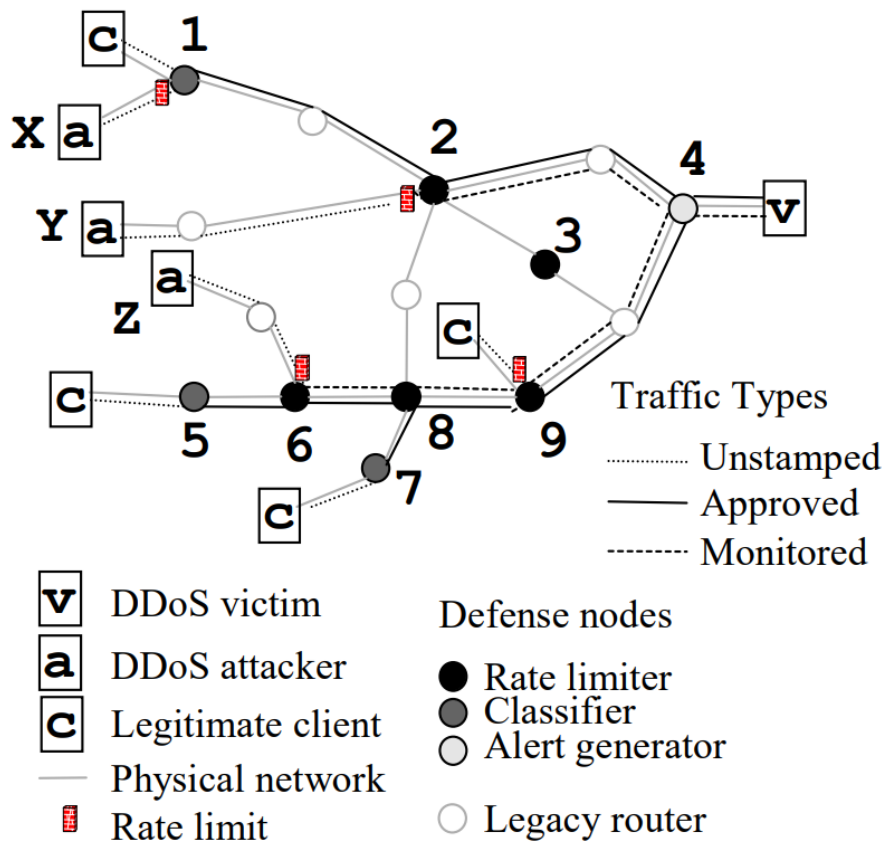


FIGURE 2.4 – Arbre de limitation de débit coopératif dans DefCOM : propagation de la demande de la victime vers les sources.

un nœud DefCOM (qui consomme des ressources pour protéger les clients d'un autre AS) est faible, posant un problème classique d'**externalité** en économie des réseaux.

- **Scalabilité de la découverte par traceroute** : La reconstruction de la topologie overlay via **traceroute** génère un volume de trafic de sondage quadratique ($O(N^2)$ pour N nœuds) et les résultats sont instables (asymétrie de routage, filtrage ICMP, load balancing).

2.6 Synthèse comparative

Le Tableau 2.1 compare les travaux analysés selon les critères clés de la coordination distribuée anti-DDoS.

Système	Architecture	P2P	Partage méta.	Sync. actions	Mutualisation
DOTS (RFC 8612)	Client-serveur	×	✓ (partiel)	✓	×
DDoS Clearing House	Centralisée	×	✓	×	×
NaWas / NBIP	Semi-centralisée	×	×	×	✓
DefCOM	P2P overlay	✓	✓ (partiel)	✓ (partiel)	×

TABLE 2.1 – Comparaison des systèmes de défense collaborative contre les attaques DDoS.

L'analyse révèle qu'aucun système existant ne combine simultanément :

1. Une architecture **véritablement décentralisée** (P2P) éliminant tout SPOF.
2. Un mécanisme de **partage de métadonnées d'attaque en temps réel** (et non *a posteriori*).
3. Une **orchestration coordonnée des actions de mitigation** entre les nœuds participants.
4. Un **modèle de confiance dynamique** permettant de vérifier la fiabilité des pairs sans relation préétablie.
5. Une **mutualisation effective des capacités** de scrubbing entre nœuds.

2.7 Conclusion

L'Étude bibliographique révèle une progression vers la défense collaborative : DOTS standardise la signalisation inter-domaines mais reste hiérarchique ; le Clearing House partage l'intelligence d'attaque mais sans orchestration active et avec un délai inhérent ; NaWas mutualise les ressources physiques mais sans coordination horizontale entre membres ; DefCOM propose une architecture overlay distribuée mais manque de mécanismes de confiance et d'interopérabilité.

Aucun système ne combine pleinement une architecture décentralisée (P2P), une coordination d'actions en temps réel, un partage d'intelligence proactif et des mécanismes de confiance robustes. C'est précisément dans cet espace que s'inscrit la contribution présentée dans les chapitres suivants de ce mémoire.

Chapitre 3

Conception et Architecture du système

3.1 Introduction

Les chapitres précédents ont mis en évidence deux constats : les attaques DDoS modernes dépassent les capacités de défense individuelles, et les systèmes collaboratifs existants souffrent d'une centralisation résiduelle ou d'une absence de mécanisme de confiance formalisé. Ce chapitre présente la conception du système distribué de mitigation collaborative qui répond à ces lacunes.

Il est organisé en deux parties : la **conception préliminaire** établit les exigences et l'architecture globale du système ; la **conception technique détaillée** formalise les modèles de données, les algorithmes et les protocoles de sécurité retenus.

3.2 Conception préliminaire

3.2.1 Périmètre du système

Le système conçu dans ce travail couvre uniquement les **échanges inter-nœuds** au sein d'une coalition de nœuds de protection déjà constitués. La formation du réseau P2P (bootstrap, découverte initiale, protocoles de routage overlay) ainsi que le filtrage effectif du trafic au niveau infrastructure sont hors périmètre. Chaque nœud est supposé opérationnel et connaître au moins un pair initial avant d'utiliser le protocole décrit ici.

Le périmètre technique se limite à trois blocs fonctionnels :

1. **Coordination collaborative** : signalement d'attaque, négociation et activation des sessions d'aide, clôture et mise à jour des crédits.
2. **Gestion de la confiance** : calcul des scores PeerTrust, détection des violations, exclusion automatique des pairs malveillants.
3. **Sécurisation des échanges** : authentification mutuelle mTLS au niveau transport, JWT RS256 au niveau applicatif.

Sont explicitement **hors périmètre** : la formation du réseau P2P, la détection réseau des attaques, la redirection effective du trafic au niveau infrastructure (configuration des tunnels GRE, VXLAN, BGP Flowspec) ainsi que le filtrage et le nettoyage du trafic (scrubbing). Le système envoie des **signaux de coordination** via l'API ; l'exécution effective au niveau réseau relève de l'infrastructure de chaque nœud.

3.2.2 Objectifs et exigences du système

Ce système est conçu autour de six exigences fondamentales :

1. **Décentralisation complète** : aucun nœud central de coordination ; chaque participant prend ses décisions de manière autonome.
2. **Confiance calculée et évolutive** : la fiabilité de chaque pair est quantifiée par un score numérique, recalculé après chaque session d'aide.
3. **Sélection multicritère** : le choix des pairs assistants repose sur quatre critères pondérés : capacité, latence, confiance et réciprocité.
4. **Sécurité de bout en bout** : toutes les communications inter-nœuds sont protégées par Mutual Transport Layer Security (mTLS) au niveau du transport et par JSON Web Token (JWT) RS256 au niveau applicatif.
5. **Traçabilité complète** : chaque événement significatif (changement de confiance, violation, session d'aide) est enregistré dans un journal d'audit.
6. **Scalabilité** : les performances doivent rester acceptables lorsque le nombre de nœuds participants dépasse la centaine.

3.2.3 Diagrammes de cas d'utilisation

Le système est décrit par trois diagrammes de cas d'utilisation complémentaires, couvrant respectivement le protocole de mitigation collaborative, le moteur de confiance PeerTrust et le rôle complet du nœud pair dans la coalition. Les trois acteurs impliqués sont : le **nœud local** (victime en situation d'attaque), le **nœud pair** (participant distant) et l'**administrateur** (responsable de la configuration locale).

3.2.3.1 Protocole de mitigation collaborative

La Figure 3.1 détaille les interactions entre le **nœud victime** et le **nœud pair** lors d'une session de mitigation. Ce diagramme couvre le flux complet depuis l'envoi de la requête d'aide jusqu'au recalcul du score de confiance.

Le nœud victime initie la séquence en **envoyant une requête d'aide** (POST /help/request), cas d'usage qui inclut obligatoirement la **sélection des pairs via l'algorithme WSM** : chaque pair candidat est évalué selon quatre critères pondérés (capacité disponible, latence inversée, score de confiance, réciprocité). Le nœud pair peut alors **accepter** (PUT /help/{id}/accept) ou **rejeter** (PUT /help/{id}/reject) la session ; l'acceptation étend optionnellement vers l'**activation de la session** (POST /traffic/redirect), qui correspond au signal de démarrage de la redirection au niveau applicatif. La **clôture de l'attaque** (POST /attack/over), déclenchée par le nœud victime, inclut deux actions systématiques : la **mise à jour des crédits de réciprocité** des deux nœuds dans leurs ledgers respectifs, et le **recalcul du score de confiance PeerTrust** $T(u)$ du pair assistant.

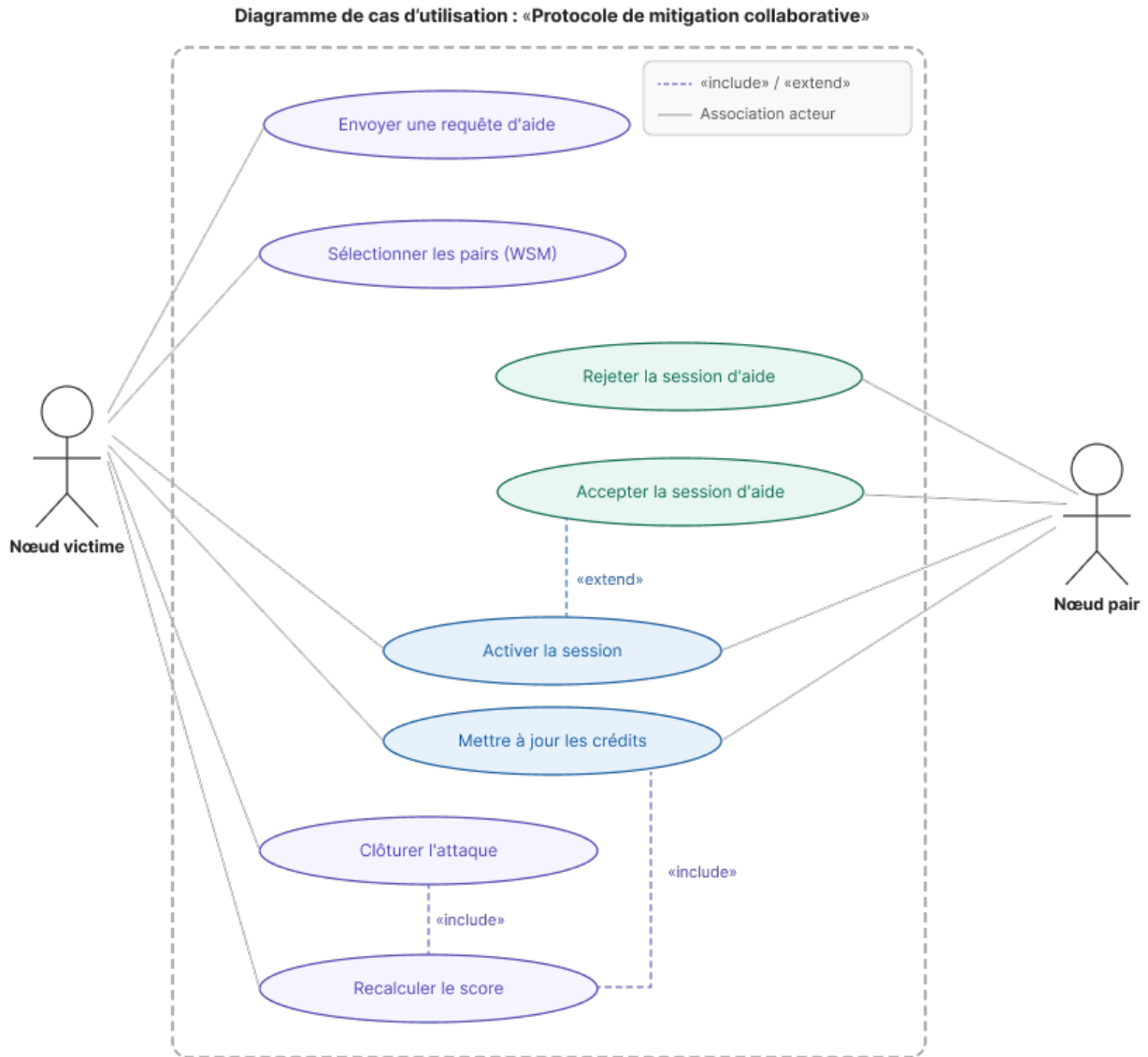


FIGURE 3.1 – Diagramme de cas d'utilisation : Protocole de mitigation collaborative.

3.2.3.2 Moteur de confiance PeerTrust

La Figure 3.2 présente les cas d'usage du moteur de confiance, centré sur le **nœud local** (évaluateur) et le **pair évalué**.

La séquence principale est déclenchée par la **clôture d'une session d'aide** : le nœud local **capture la crédibilité** Cr_i du réseau au moment de la session en interrogeant les pairs actifs (GET /trust/{node_id} sur chaque pair), puis **calcule le score PeerTrust** $T(u) = \sum[S \cdot Cr_i \cdot D] / \sum[Cr_i \cdot D]$ et **met à jour le niveau de confiance** (GOLD $\geq 0,80$; SILVER $\geq 0,60$; BRONZE $\geq 0,40$; SUSPECT $\geq 0,20$; BANNED $< 0,20$). Si le score calculé est inférieur à 0,20, la mise à jour du niveau étend automatiquement vers le **bannissement automatique** du pair (statut BANNED, membership EXPELLED). Indépendamment de ce flux, une **violation de comportement** détectée peut également déclencher le bannissement via le même mécanisme d'extension. Le **pair évalué** dispose d'un accès en lecture via **Consulter le score de confiance** (GET /trust/{id}). Enfin, l'administrateur ou le système peut **forcer le recalcul du score** (POST /trust/{id}/recalculate) à tout moment, ce cas d'usage incluant directement le calcul de $T(u)$.

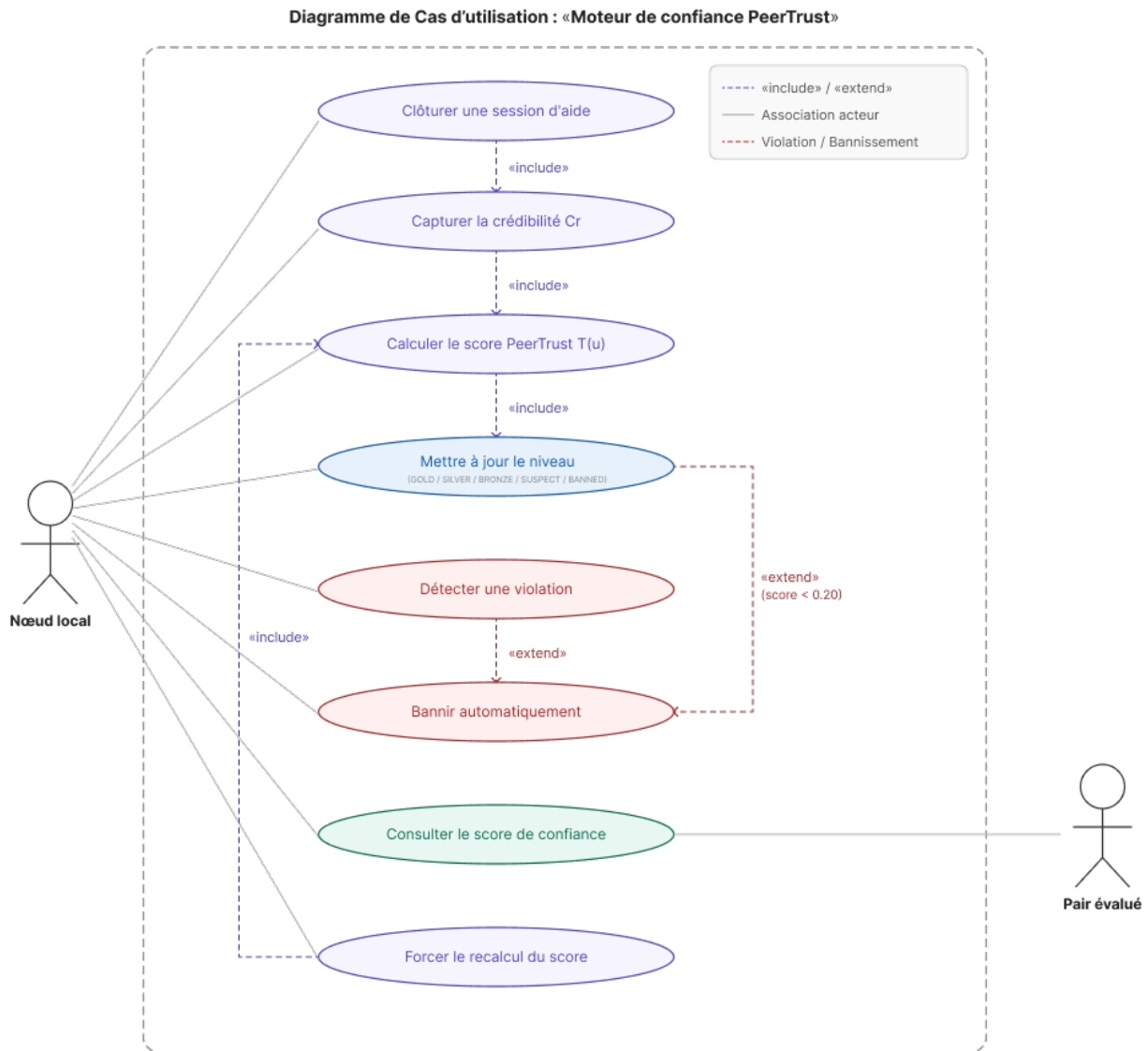


FIGURE 3.2 – Diagramme de cas d'utilisation : Moteur de confiance PeerTrust.

3.2.3.3 Rôle du nœud pair dans la coalition

La Figure 3.3 présente l'ensemble des actions qu'un **nœud pair** peut effectuer au sein de la coalition, organisées en quatre groupes fonctionnels.

Le groupe **Membership** couvre le cycle de vie complet du pair : il s'enregistre via `POST /peers/register`, action qui inclut obligatoirement la **publication de ses capacités de scrubbing** (`POST /capability/advertise`); il peut ensuite **découvrir des pairs disponibles** (`POST /peers/discover`) et **consulter la liste des pairs connus** (`GET /peers`); il envoie périodiquement un **heartbeat** (`POST /heartbeat`) — toutes les 30 secondes par défaut — pour signaler sa disponibilité et mettre à jour sa capacité déclarée; enfin, il peut **quitter proprement la coalition** (`POST /peers/goodbye`), ce qui met son statut à `INACTIVE` ou `MAINTENANCE`.

Le groupe **Session d'aide** couvre les deux modes de participation : le pair peut **recevoir une requête d'aide** (`POST /help/request`) et choisir de l'**accepter** (`PUT /help/{id}/accept`) ou de la **rejeter** (`PUT /help/{id}/reject`), ou bien **proposer proactivement de l'aide** (`POST /help/offer`) lorsque le flag `auto_offer_enabled` est activé dans sa politique locale; une offre acceptée étend vers le même cas d'usage *Accepter*

la session d'aide.

Le groupe **Confiance** contient un seul cas d'usage : **interroger la coalition sur sa réputation** (GET /trust/{self_id} appelé sur les APIs des pairs actifs), qui correspond à la collecte de la crédibilité Cr utilisée dans la formule PeerTrust.

Le groupe **Sécurité** couvre l'**obtention d'un token JWT RS256** (POST /auth/token), prérequis à tout appel API authentifié.

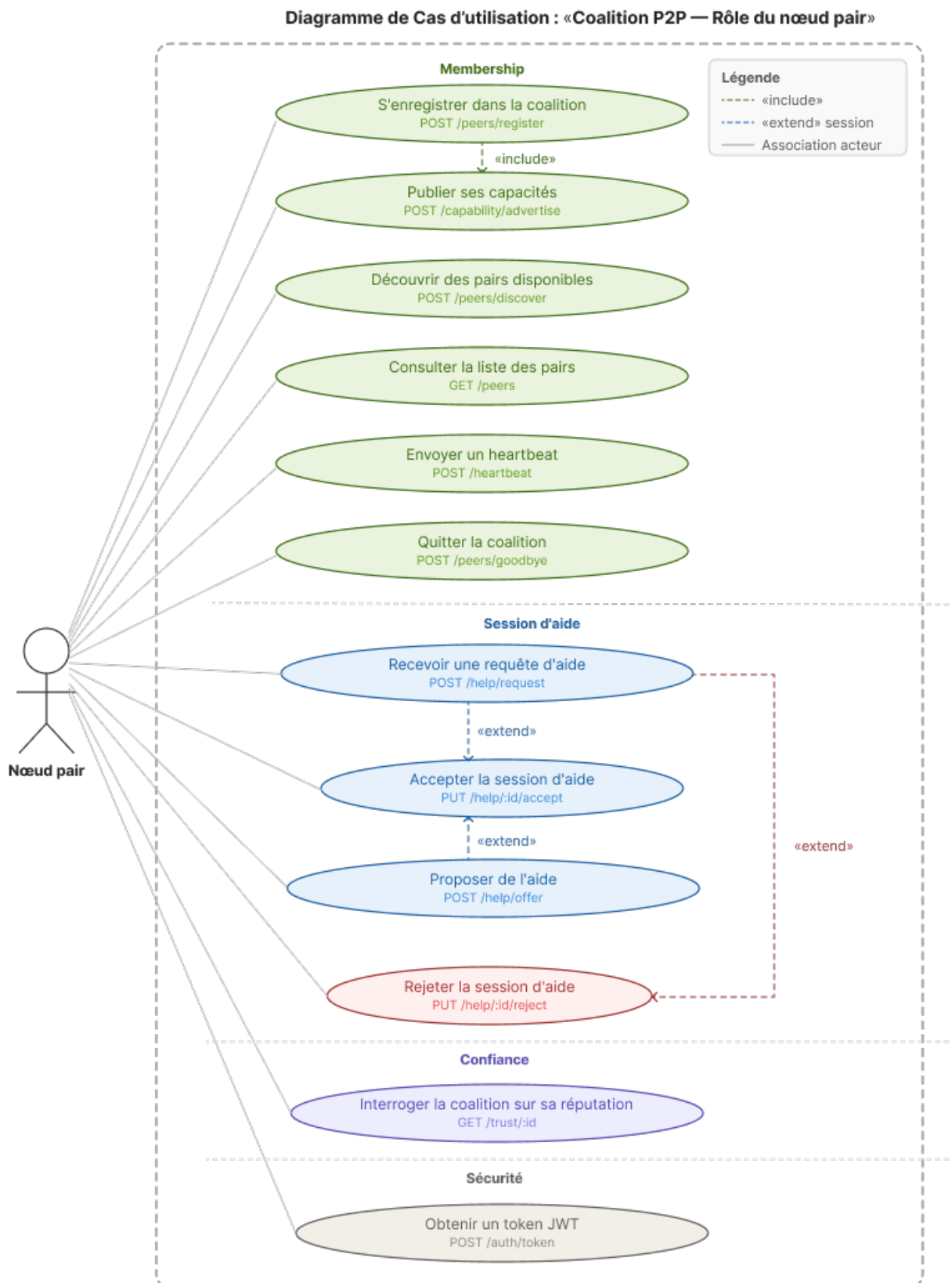


FIGURE 3.3 – Diagramme de cas d'utilisation : Rôle du nœud pair dans la coalition (12 cas d'usage).

3.2.4 Documentation des cas d'utilisation

Les tableaux suivants documentent les sept principaux cas d'utilisation du système, issus des trois diagrammes présentés ci-dessus.

CU 1 : Obtenir un token JWT RS256	
ID	1
Description	Le nœud (local ou pair) demande un token JWT signé RS256 afin d'accéder aux routes protégées de l'API. Le token est valide exactement 60 secondes.
Acteurs principaux	Nœud local, nœud pair
Acteurs secondaires	Module d'authentification (composant interne du nœud cible)
Préconditions	La clé privée RSA du nœud (<code>node.key</code>) est présente sur le système de fichiers.
Enchaînement principal	Ce CU démarre lorsque le nœud doit appeler une route protégée de l'API. 1. Le nœud envoie <code>POST /api/v1/auth/token</code> avec son identifiant (<code>node_id</code>). 2. Le module d'authentification lit la clé privée RS256 stockée localement (<code>node.key</code>). 3. Le système génère un JWT signé contenant <code>{iss, node_id, iat, exp}</code> avec une durée de vie de 60 secondes. 4. Le token est retourné au nœud appelant (HTTP 200). 5. Le nœud inclut ce token dans l'en-tête <code>Authorization: Bearer <token></code> pour toutes ses requêtes suivantes.
Post-conditions	Le nœud dispose d'un token RS256 valide pour 60 secondes.
Enchaînements alternatifs	Clé privée introuvable : le serveur retourne HTTP 500. Token expiré lors d'un appel ultérieur : le serveur retourne HTTP 401; le nœud doit redemander un token via ce même CU.

TABLE 3.1 – Documentation du cas d'utilisation *Obtenir un token JWT RS256*.

CU 2 : S'enregistrer dans la coalition	
ID	2
Description	Un nœud pair rejoint la coalition en publiant son identité, sa clé publique RSA et ses capacités de scrubbing auprès du nœud local.
Acteurs primaires	Nœud pair
Acteurs secondaires	Nœud local (registre de la coalition)
Préconditions	Le nœud pair dispose d'une paire de clés RSA et connaît l'URL du nœud cible. Aucune authentification JWT n'est requise pour cette route (publique).
Enchaînement principal	Ce CU démarre lorsque l'administrateur lance le démarrage d'un nouveau nœud pair. 1. Le pair envoie <code>POST /api/v1/peers/register</code> avec : <code>peer_id</code> (UUID), <code>peer_name</code>, <code>public_key</code> (PEM), type d'organisation, tier (T1/T2/T3) et capacité maximale de scrubbing (<code>max_scrubbing_capacity_gbps</code>). 2. Le nœud local vérifie l'unicité du <code>peer_id</code>. 3. Les informations du pair sont enregistrées en base avec le score de confiance initial de 0,50 et le statut ACTIVE. 4. Le nœud local retourne une confirmation HTTP 201 au pair.
Post-conditions	Le pair est connu de la coalition avec le statut ACTIVE et un score de confiance initial de 0,50.
Enchaînements alternatifs	Pair déjà enregistré (<code>peer_id</code> existant) : le nœud retourne HTTP 409 (Conflict). Données obligatoires manquantes : le nœud retourne HTTP 400 (Bad Request).

TABLE 3.2 – Documentation du cas d'utilisation *S'enregistrer dans la coalition*.

CU 3 : Envoyer un heartbeat	
ID	3
Description	Un nœud pair signale périodiquement (toutes les 30 secondes) sa disponibilité et met à jour sa capacité disponible auprès du nœud local.
Acteurs primaires	Nœud pair
Acteurs secondaires	Nœud local (registre de la coalition)
Préconditions	Le nœud pair est enregistré (statut ACTIVE) et possède un token JWT valide (CU 1).
Enchaînement principal	Ce CU est déclenché automatiquement toutes les 30 secondes par le processus de monitoring du pair. 1. Le pair envoie POST /api/v1/heartbeat avec : peer_id, la charge actuelle (reported_load_pct), la capacité disponible (reported_available_gbps) et la latence aller-retour mesurée (round_trip_time_ms). 2. Le nœud local met à jour le champ last_seen du pair et ses métriques en temps réel. 3. Le nœud local retourne HTTP 200 avec le statut courant du pair.
Post-conditions	Le champ last_seen est mis à jour ; la capacité disponible reflète l'état réel du pair.
Enchaînements alternatifs	Pair banni ou inconnu : le nœud retourne HTTP 403 (Forbidden). Token JWT expiré : le nœud retourne HTTP 401 ; le pair doit se réauthentifier (CU 1) avant de retenter.

TABLE 3.3 – Documentation du cas d'utilisation *Envoyer un heartbeat*.

CU 4 : Envoyer une requête d'aide (sélection WSM)	
ID	4
Description	Le nœud victime, confronté à un volume d'attaque DDoS dépassant sa capacité locale, sélectionne automatiquement des pairs assistants via l'algorithme WSM et leur envoie une requête d'aide.
Acteurs primaires	Nœud victime (nœud local sous attaque)
Acteurs secondaires	Nœuds pairs candidats
Préconditions	Le nœud victime est authentifié (CU 1) ; au moins un pair est en statut ACTIVE dans la coalition.
Enchaînement principal	Ce CU démarre lorsque le volume d'attaque DDoS dépasse la capacité de filtrage locale du nœud. 1. Le nœud victime appelle <code>POST /api/v1/trust/select-peers</code> pour déclencher la sélection WSM. 2. Le système calcule pour chaque pair candidat (statut ACTIVE, non banni) le score pondéré : $\text{Score}(p) = 0,52 \cdot C_p + 0,20 \cdot L_p + 0,20 \cdot T_p + 0,08 \cdot R_p$ où C_p est la capacité disponible, L_p la latence inversée, T_p le score de confiance et R_p la réciprocité. 3. Les pairs sont classés par score décroissant. 4. Le nœud victime envoie <code>POST /api/v1/help/request</code> aux pairs les mieux classés, en précisant le volume requis (<code>volume_requested_gbps</code>). 5. Une session d'aide est créée côté pair avec le statut PENDING.
Post-conditions	Des sessions d'aide en statut PENDING existent chez les pairs sélectionnés.
Enchaînements alternatifs	Aucun pair disponible (tous saturés ou bannis) : le système retourne une liste vide ; le nœud victime gère l'attaque seul. Pair banni inclus dans la liste initiale : le pair banni est automatiquement exclu du classement WSM.

TABLE 3.4 – Documentation du cas d'utilisation *Envoyer une requête d'aide (sélection WSM)*.

CU 5 : Accepter ou rejeter une session d'aide	
ID	5
Description	Un nœud pair, ayant reçu une requête d'aide (CU 4), évalue sa capacité disponible et accepte ou rejette la session.
Acteurs primaires	Nœud pair
Acteurs secondaires	Nœud victime
Préconditions	Une session d'aide en statut PENDING est associée au pair ; le pair est authentifié (CU 1).
Enchaînement principal	Ce CU démarre dès réception d'une requête POST /help/request par le nœud pair. 1. Le pair consulte sa capacité disponible (reported_available_gbps) et sa charge actuelle (reported_load_pct). 2. Si la capacité est suffisante pour absorber le volume demandé : * Le pair envoie PUT /api/v1/help/{id}/accept ; la session passe en statut ACCEPTED. * Le nœud victime est notifié ; la redirection du trafic peut démarrer. 3. Si la capacité est insuffisante : * Le pair envoie PUT /api/v1/help/{id}/reject ; la session passe en statut REJECTED. * Le nœud victime est notifié du refus et peut consulter d'autres pairs candidats.
Post-conditions	La session est en statut ACCEPTED ou REJECTED ; le nœud victime est informé de la décision.
Enchaînements alternatifs	Session déjà traitée (statut non PENDING) : le nœud retourne HTTP 409 (Conflict). Token JWT expiré : le nœud retourne HTTP 401.

TABLE 3.5 – Documentation du cas d'utilisation *Accepter ou rejeter une session d'aide*.

CU 6 : Clôturer l'attaque	
ID	6
Description	À la fin de l'attaque DDoS, le nœud victime clôture la session d'aide, met à jour les crédits de réciprocité des deux nœuds et déclenche le recalcul du score de confiance PeerTrust de chaque pair assistant.
Acteurs principaux	Nœud victime
Acteurs secondaires	Nœuds pairs assistants, moteur de confiance PeerTrust
Préconditions	Au moins une session d'aide est en statut <code>IN_PROGRESS</code> ; le nœud victime est authentifié (CU 1).
Enchaînement principal	Ce CU démarre lorsque le nœud victime détecte la fin de l'attaque DDoS. 1. Le nœud victime envoie <code>POST /api/v1/attack/over</code> avec le <code>session_id</code> et le volume réellement traité par le pair (<code>actual_volume_gbps</code>). 2. Le système calcule le ratio de satisfaction $S = \min(1,0, \text{réel}/\text{accepté})$ pour chaque pair assistant. 3. Les crédits de réciprocité sont mis à jour dans les ledgers respectifs du nœud victime et du pair assistant. 4. Le moteur de confiance recalcule le score PeerTrust $T(u)$ de chaque pair assistant (CU 7). 5. La session est marquée <code>COMPLETED</code>.
Post-conditions	Session en statut <code>COMPLETED</code> ; scores de confiance et crédits de réciprocité mis à jour.
Enchaînements alternatifs	Session introuvable : le système retourne HTTP 404. Volume réel nul ($S = 0$, pair n'a rien traité) : le score PeerTrust chute ; si $T(u) < 0,20$, le bannissement automatique est déclenché (CU 7).

TABLE 3.6 – Documentation du cas d'utilisation *Clôturer l'attaque*.

CU 7 : Recalculer le score PeerTrust (bannissement automatique)	
ID	7
Description	Le moteur de confiance recalcule le score PeerTrust $T(u)$ d'un pair à partir de l'historique de ses interactions. Si $T(u) < 0,20$, le bannissement automatique est déclenché.
Acteurs primaires	Moteur de confiance (système)
Acteurs secondaires	Pair évalué, pairs actifs (source de la crédibilité réseau Cr)
Préconditions	Au moins une interaction du pair est enregistrée en base ; ce CU est inclus par CU 6 ou déclenché manuellement via <code>POST /api/v1/trust/{id}/recalculate</code> .
Enchaînement principal	Ce CU démarre automatiquement à la clôture d'une session (CU 6) ou sur demande explicite. 1. Le système collecte la crédibilité réseau Cr_i en interrogeant les pairs actifs (<code>GET /api/v1/trust/{node_id}</code> sur chacun d'eux). 2. Le système calcule le score PeerTrust selon la formule de Xiong & Liu (2004) : $T(u) = \sum_i [S_i \cdot Cr_i \cdot D_i] / \sum_i [Cr_i \cdot D_i]$ où $S_i = \min(1, \text{réel}_i / \text{accepté}_i)$ et D_i est le poids de sévérité de l'attaque. 3. Le niveau de confiance est mis à jour selon les seuils : * $T(u) \geq 0,80$: niveau GOLD * $T(u) \geq 0,60$: niveau SILVER * $T(u) \geq 0,40$: niveau BRONZE * $T(u) \geq 0,20$: niveau SUSPECT * $T(u) < 0,20$: niveau BANNED → bannissement automatique 4. En cas de bannissement : le statut du pair passe à BANNED et son membership à EXPELLED.
Post-conditions	Le score $T(u)$ et le niveau de confiance du pair sont persistés en base.
Enchaînements alternatifs	Aucune interaction enregistrée : le score reste inchangé à sa valeur initiale (0,50). Pairs actifs inaccessibles pour Cr : la valeur par défaut $Cr_i = 1,0$ est utilisée (confiance pleine dans l'interaction locale).

TABLE 3.7 – Documentation du cas d'utilisation *Recalculer le score PeerTrust*.

3.2.5 Architecture générale

3.2.5.1 Topologie de la coalition

La solution proposée adopte une topologie P2P **Pair-à-Pair** : chaque nœud maintient localement un registre des pairs connus, sans table de hachage distribuée (DHT) ni super-pair central. Ce choix a été retenu pour trois raisons :

- **Hétérogénéité des participants** : universités, PME, opérateurs et datacenters ont des capacités très variables ; une topologie plate évite de favoriser arbitrairement certains nœuds.
- **Résilience** : la disparition d'un pair n'affecte pas la connectivité des autres.
- **Simplicité de déploiement** : chaque nœud n'a besoin que d'une adresse d'entrée initiale pour rejoindre la coalition.

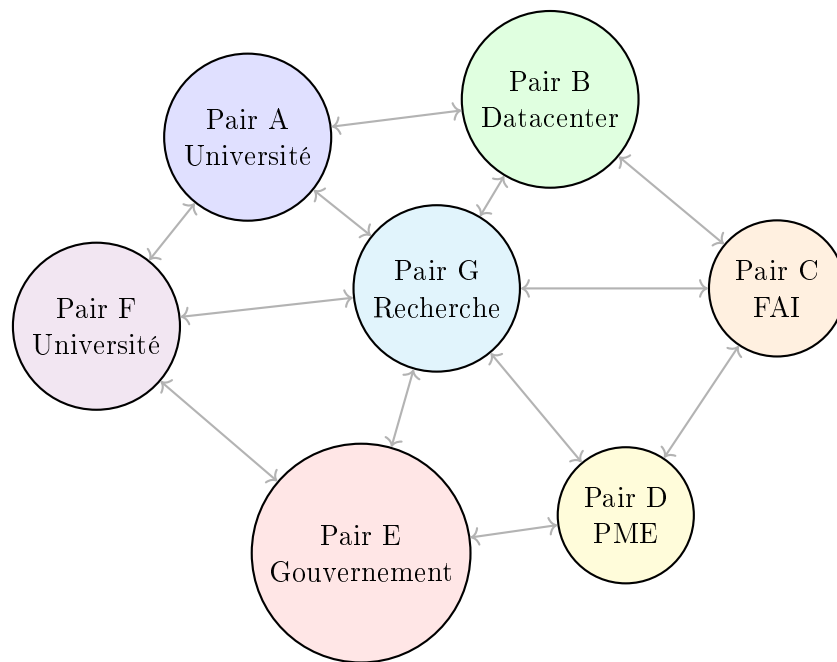


FIGURE 3.4 – Exemple de coalition : sept nœuds h t rog nes interconnect s en overlay P2P plat non structur .

3.2.5.2 Cycle de vie d'une session de mitigation

Le flux d'une session d'aide suit quatre phases distinctes :

1. **D tection et escalade** : le n ud victime d tecte un d bordement et s lectionne les pairs assistants via l'algorithme WSM.
2. **N gociation** : les pairs re oivent une requ te `POST /help/request` et acceptent ou rejettent en fonction de leur capacit  disponible.
3. **Redirection active** : le trafic exc dentaire est redirig  vers les pairs acceptants via un tunnel (GRE, VXLAN ou BGP Flowspec).
4. **Cl ture** :   la fin de l'attaque, le n ud victime notifie la cl ture (`POST /attack/over`), capture les cr dibilit s r seau au moment de la session et recalcule les scores de confiance.

(un score agrégé par pair, mis à jour en place), **TRUST_VIOLATIONS** (historique des comportements anormaux), **HEARTBEAT_LOG** (signaux de présence), **RECIPROCITY_LEDGER** (solde crédit/débit unique par pair) et **MESSAGE_LOG** (journal des échanges, avec une auto-relation (0,1)-(0,N) pour les messages de réponse). La table **PEER_CAPABILITIES** complète ce profil pair avec les capacités déclarées et vérifiées.

Le nœud local est décrit par **LOCAL_NODE_CONFIG**, dont dépendent **SCRUBBING_CAPABILITY** (capacités techniques, relation (1,1)-(0,1)) et **POLICY_CONFIG** (paramètres de politique locale : confiance minimale, partage de capacité, intervalle de heartbeat). Les sessions de mitigation sont modélisées par **HELP_SESSIONS**, reliée à **ATTACKS** par une clé étrangère en cascade et au pair assistant (**PEERS**) avec une contrainte **RESTRICT**. Chaque session peut générer plusieurs transactions dans **RECIPROCITY_TRANSACTIONS**, liée à la fois à **HELP_SESSIONS** (SET NULL) et à **PEERS** (CASCADE). Enfin, **AUDIT_LOG** est une table autonome sans clé étrangère : ses colonnes **actor** et **target** sont de type texte libre, ce qui garantit la persistance des entrées même après suppression d'un pair.

3.3.1.2 Identifiants et intégrité référentielle

Toutes les clés primaires sont des Universally Unique Identifier (UUID) version 4, générés localement par chaque nœud. Ce choix garantit l'unicité globale sans coordinateur centralisé et facilite la fusion éventuelle de registres entre nœuds lors de la découverte. Les suppressions en cascade sont configurées pour les entités dépendantes (sessions, scores de confiance, ledger) afin de maintenir l'intégrité référentielle lors du retrait d'un pair.

3.3.2 Modèle de confiance : PeerTrust adapté

3.3.2.1 Motivation du choix de PeerTrust

La littérature propose plusieurs modèles de réputation pour les systèmes P2P. Le modèle PeerTrust [27] a été retenu pour trois raisons :

- Il intègre nativement un **facteur contextuel** $D(u, i)$ permettant de pondérer les transactions selon leur importance (ici, la sévérité de l'attaque).
- Il inclut un mécanisme de **crédibilité** $Cr(p)$ qui réduit l'influence des évaluateurs peu fiables.
- Sa formule est suffisamment simple pour être recalculée en temps réel après chaque session.

3.3.2.2 Formule $T(u)$ et ses paramètres

Le score de confiance $T(u)$ d'un pair u est calculé selon l'équation :

$$T(u) = \frac{\sum_{i=1}^n S(u, i) \cdot Cr_i \cdot D(u, i)}{\sum_{i=1}^n Cr_i \cdot D(u, i)} \quad (3.1)$$

où n est le nombre de sessions complétées, et les trois paramètres sont définis comme suit :

- $S(u, i) = \min\left(1, \frac{V_{\text{réel}}}{V_{\text{accepté}}}\right)$ est la **satisfaction normalisée** de la session i : rapport entre le volume effectivement filtré et le volume promis par le pair. $S \in [0, 1]$.

TABLE 3.8 – Description des tables de la base de données.

Table	Rôle
LOCAL_NODE_CONFIG	Configuration du nœud local : identité, capacité, clé publique, statut.
PEERS	Registre des pairs connus : organisation, tier, URL d’API, clé publique, statut de membership.
TRUST_SCORES	Score de confiance courant d’un pair : valeur globale, niveau (GOLD à BANNED), date de dernier calcul.
ATTACKS	Journal des attaques détectées : volume, sévérité, statut, pairs impliqués.
HELP_SESSIONS	Sessions d’aide inter-nœuds : volumes acceptés et réels, statut, Cr capturé à la clôture.
RECIPROCITY_LEDGER	Solde de réciprocité d’un pair : crédits donnés et reçus en Gbps cumulés.
POLICY_CONFIG	Paramètres de politique locale : score de confiance minimal requis pour aider, pourcentage de capacité partageable, fréquence de heartbeat, activation des offres automatiques.
TRUST_VIOLATIONS	Violations de comportement détectées : type, sévérité, sanction appliquée.
HEARTBEAT_LOG	Historique des messages de présence reçus des pairs.
AUDIT_LOG	Journal d’audit immuable : changements de confiance, bannissements, échecs d’authentification.
SCRUBBING_CAPABILITY	Capacités techniques du nœud local : type de filtrage, protocoles supportés.
MESSAGE_LOG	Journal des messages échangés entre nœuds : type, direction (entrant/sortant), validité de signature, résultat de traitement.
PEER_CAPABILITIES	Capacités déclarées et vérifiées d’un pair : capacité en Gbps, statut de vérification, date de mise à jour.
RECIPROCITY_TRANSACTIONS	Journal détaillé des transactions de réciprocité : type, montant en crédits, session associée, horodatage.

- Cr_i est la **crédibilité historique** du nœud local au moment de la session i : moyenne des scores que les pairs actifs du réseau attribuent au nœud local, capturée à la clôture de la session et persistée dans le champ `cr_value` de la table `HELP_SESSIONS`. Cette approche garantit que chaque session est évaluée avec la crédibilité en vigueur à l'époque des faits.
- $D(u, i)$ est le **facteur contextuel** lié à la sévérité de l'attaque de la session i . Les valeurs retenues sont présentées dans le Tableau 3.9.

TABLE 3.9 – Facteur contextuel $D(u, i)$ selon la sévérité de l'attaque.

Sévérité	$D(u, i)$	Seuil de volume
LOW	0.25	< 1 Gbps
MEDIUM	0.50	1 – 10 Gbps
HIGH	0.75	10 – 100 Gbps
CRITICAL	1.00	> 100 Gbps

Les seuils de volume et les valeurs de $D(u, i)$ constituent des **choix de conception** motivés par deux considérations :

- **Seuils de volume** : les bornes < 1 Gbps, 1–9 Gbps, 10–99 Gbps et ≥ 100 Gbps sont directement inspirées de la classification par sévérité utilisée par StormWall [25], fournisseur industriel de protection DDoS, qui définit quatre niveaux (*Low*, *Medium*, *High*, *Very High*) sur ces mêmes bornes volumétriques. Le niveau *Very High* de StormWall est renommé CRITICAL dans notre système pour refléter son caractère maximal.
- **Valeurs de $D(u, i)$** : elles forment une **progression arithmétique régulière de pas 0,25**, ancrée à $D = 1,00$ pour CRITICAL (poids maximal) et à $D = 0,25$ pour LOW (poids minimal non nul, afin que même les sessions mineures contribuent au score). Ce choix s'inscrit dans le cadre de Xiong et Liu [27], qui laissent explicitement la définition de $D(u, i)$ à l'appréciation du concepteur, en précisant qu'il doit refléter l'importance relative de la transaction dans son contexte opérationnel.

La normalisation par $\sum Cr_i \cdot D(u, i)$ garantit $T(u) \in [0, 1]$ sans troncature artificielle, en s'inspirant du schéma de normalisation de l'équation 3 de Xiong et Liu [27]. Une session avec une sévérité CRITICAL a un poids quatre fois supérieur à une session LOW : aider lors d'une attaque massive est valorisé davantage.

3.3.2.3 Niveaux de confiance

Le score numérique $T(u)$ est converti en un niveau discret selon les seuils du Tableau 3.10. Le niveau BANNED déclenche automatiquement l'exclusion du pair de la coalition : son statut passe à EXPELLED et il ne reçoit plus de requêtes d'aide.

3.3.3 Algorithme de sélection des pairs : WSM

3.3.3.1 Critères de sélection

Lorsqu'un nœud doit sélectionner des pairs assistants, il calcule pour chaque candidat un score composite selon le **Weighted Sum Model** (WSM) :

TABLE 3.10 – Niveaux de confiance dans le système.

Niveau	Seuil $T(u)$	Signification opérationnelle
GOLD	≥ 0.80	Pair prioritaire dans la sélection
SILVER	≥ 0.60	Pair fiable, sélectionnable normalement
BRONZE	≥ 0.40	Pair acceptable ; score initial par défaut
SUSPECT	≥ 0.20	Pair sous surveillance ; pondération réduite
BANNED	< 0.20	Exclusion automatique de la coalition

$$\text{Score}(p) = w_C \cdot C_p + w_L \cdot L'_p + w_T \cdot T_p + w_R \cdot R_p \quad (3.2)$$

Les quatre critères sont définis comme suit :

- $C_p = \frac{\text{cap_disp}(p)}{\max_j(\text{cap_disp}(j))}$: capacité disponible normalisée.
- $L'_p = 1 - \frac{L_p - L_{\min}}{L_{\max} - L_{\min}}$: latence normalisée inversée (une latence faible donne un score élevé).
- T_p : score de confiance PeerTrust du pair p .
- $R_p = \frac{\text{crédits_reçus}}{\text{crédits_reçus} + \text{crédits_donnés} + \varepsilon}$: réciprocité bilatérale ; $\varepsilon = 10^{-6}$ pour éviter la division par zéro.

3.3.3.2 Pondération AHP

Les poids w_C, w_L, w_T, w_R ont été déterminés par la méthode AHP de Saaty [21]. La matrice de comparaison par paires (Tableau 3.11) exprime les préférences relatives entre critères ; la cohérence est vérifiée par le **ratio de cohérence** $\text{CR} = 1,6\% < 10\%$, ce qui valide les poids retenus.

TABLE 3.11 – Matrice AHP de comparaison des critères de sélection des pairs.

Critère	Capacité	Latence	Confiance	Réciprocité	Poids w
Capacité (C_p)	1	3	3	7	0.52
Latence (L'_p)	1/3	1	1	3	0.20
Confiance (T_p)	1/3	1	1	3	0.20
Réciprocité (R_p)	1/7	1/3	1/3	1	0.08
Ratio de cohérence CR					1,6 %

La capacité disponible reçoit le poids dominant (0.52) car c'est le facteur limitant direct lors d'une attaque volumétrique : un pair très fiable mais saturé ne peut pas contribuer efficacement. La latence et la confiance ont des poids égaux (0.20 chacun) ; la réciprocité, facteur d'équité à long terme, est pondérée à 0.08.

3.3.3.3 Répartition proportionnelle du flux

Tous les pairs éligibles participent à la mitigation. Le flux est réparti proportionnellement aux scores WSM :

$$w_i = \frac{\text{Score}(p_i)}{\sum_j \text{Score}(p_j)}, \quad \text{allocation}(p_i) = \lfloor w_i \times 100 \rfloor \% \quad (3.3)$$

Si le volume excédentaire total V_{overflow} est connu, le volume estimé alloué à chaque pair est :

$$V_i = \min(w_i \times V_{\text{overflow}}, \text{cap_disp}(p_i)) \quad (3.4)$$

Le plafonnement par la capacité réelle du pair évite de lui demander plus qu'il ne peut absorber.

3.3.4 Diagramme d'activités : session de mitigation

La Figure 3.6 illustre le flux d'activités d'une session de mitigation collaborative, réparti en deux couloirs : le **nœud victime** et le **nœud pair**. Dès la détection d'une attaque DDoS, le nœud victime sélectionne les pairs candidats via l'algorithme WSM. Si aucun pair n'est disponible, le nœud subit l'attaque sans aide extérieure. Dans le cas contraire, une demande d'aide est envoyée (`POST /help/request`) ; le pair vérifie le score de confiance du demandeur ainsi que sa capacité disponible avant d'accepter ou de rejeter la session. En cas d'acceptation, un tunnel est établi (GRE/VXLAN/IPSec) et le trafic malveillant est scrubé côté pair. À la fin de l'attaque, le nœud victime notifie la clôture (`POST /attack/over`) ; les crédits de réciprocité et les scores de confiance sont alors mis à jour.

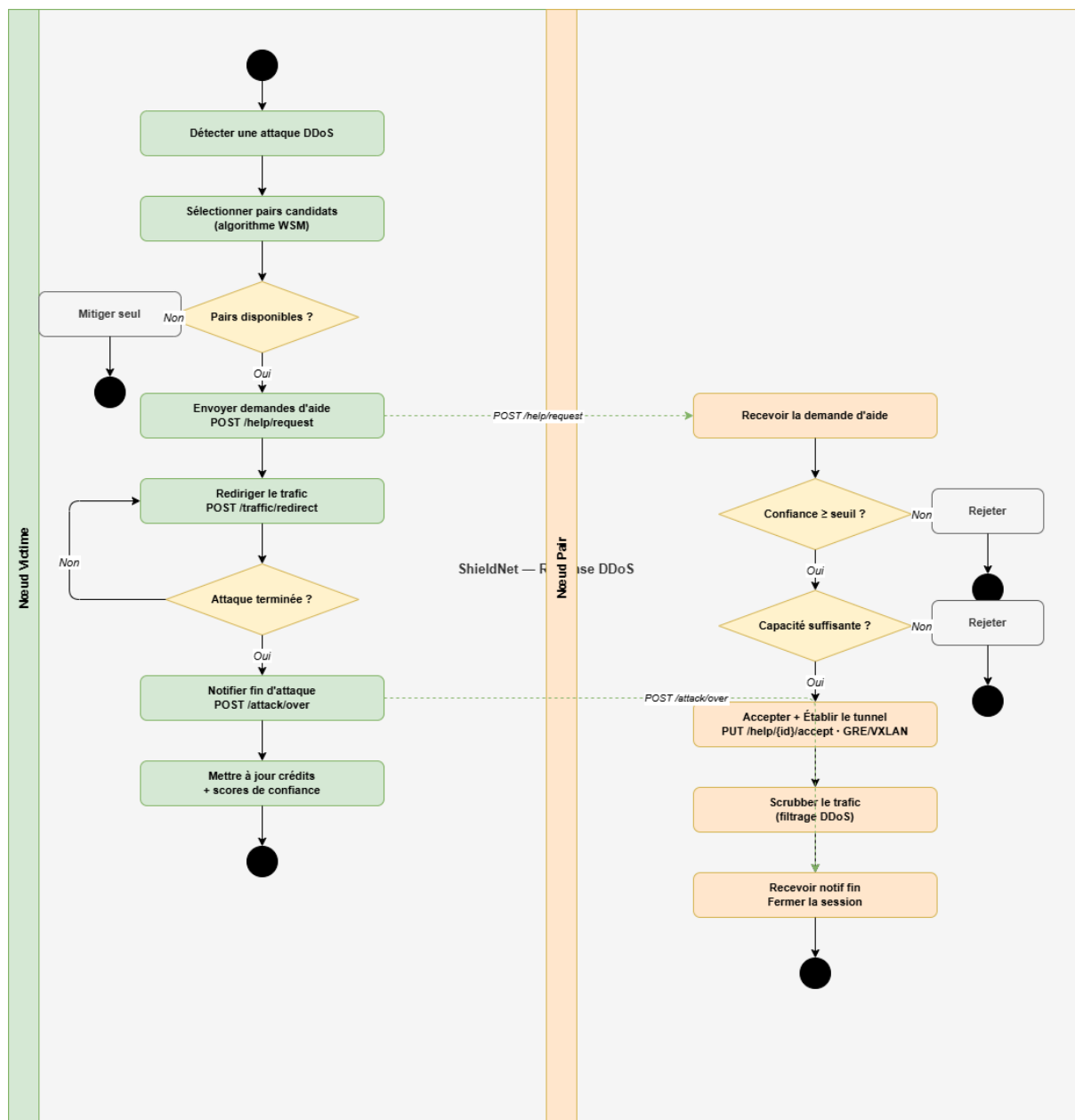


FIGURE 3.6 – Diagramme d’activités d’une session de mitigation collaborative (deux couloirs : nœud victime et nœud pair).

3.3.5 Mécanismes de sécurité

3.3.5.1 Transport sécurisé : mTLS

Toutes les communications entre nœuds transitent sur Transport Layer Security (TLS) 1.3 [19] en mode **mutuel** (mTLS) : le serveur présente son certificat au client, mais le client doit également présenter le sien. Ce mécanisme garantit que seuls les nœuds disposant d'un certificat valide (délivré lors de l'enregistrement dans la coalition) peuvent établir une connexion.

Chaque nœud stocke :

- `certs/node.key` : clé privée RSA du nœud local.
- `certs/node.crt` : certificat auto-signé du nœud local.

L'empreinte du certificat de chaque pair est stockée dans le champ `certificate_fingerprint` de la table `PEERS` pour vérification lors de la connexion.

3.3.5.2 Authentification applicative : JWT RS256

Au-dessus de mTLS, chaque requête API porte un JWT [7] signé en RS256 [6]. L'architecture asymétrique choisie présente des avantages importants par rapport à un HMAC partagé :

- **Pas de secret partagé** : chaque nœud signe avec sa clé privée ; les autres vérifient avec sa clé publique (stockée dans `PEERS.public_key`). La compromission d'un nœud n'expose pas les autres.
- **Non-répudiation** : la signature RS256 lie le token à l'identité du nœud émetteur.
- **Courte durée de vie** : les tokens expirent après 60 secondes, limitant la fenêtre d'exploitation en cas d'interception.

Le *payload* du JWT contient : `iss` (identifiant du nœud émetteur), `node_id` et `exp` (timestamp d'expiration). Le middleware d'authentification valide séquentiellement : décodage sans vérification pour extraire `iss`, récupération de la clé publique correspondante, puis vérification cryptographique de la signature.

3.3.6 Interface API REST

3.3.6.1 Style architectural

Le style architectural retenu pour l'interface de communication inter-nœuds est **REST** (*Representational State Transfer*), introduit par Fielding [5]. Ce choix repose sur trois propriétés fondamentales qui correspondent aux contraintes du système :

- **Sans état (*stateless*)** : chaque requête HTTP porte toutes les informations nécessaires à son traitement (identité du nœud dans le JWT, paramètres dans le corps). Aucun nœud serveur ne maintient de session active côté client, ce qui est cohérent avec la topologie P2P décentralisée où aucun nœud n'a de rôle privilégié.
- **Interface uniforme** : les ressources métier (pairs, attaques, sessions d'aide, scores de confiance) sont identifiées par des URI stables et manipulées via les verbes HTTP sémantiques — `POST` pour créer, `PUT` pour mettre à jour, `GET` pour consulter — ce qui rend l'API intuitive et interopérable entre nœuds hétérogènes.
- **Interopérabilité** : le transport HTTP/JSON est supporté nativement par tous les langages et environnements, facilitant l'intégration future de nœuds développés sur des plateformes différentes.

Les alternatives GraphQL (sur-ingénierie pour des requêtes fixes), gRPC (couplage fort via Protocol Buffers) et WebSocket (connexion persistante inadaptée à des échanges ponctuels) ont été écartées car leurs avantages ne compensent pas la complexité qu’elles introduiraient dans un contexte P2P à faible coordination.

3.3.6.2 Endpoints

Chaque nœud expose une API REST HTTPS documentée via OpenAPI 3.0. Le Tableau 3.12 présente les endpoints principaux, regroupés par domaine fonctionnel.

TABLE 3.12 – Endpoints principaux de l’API REST.

Méthode	Endpoint	Description
<i>Découverte et membership</i>		
POST	/peers/register	Enregistrement d’un nouveau pair dans la coalition
GET	/peers	Liste des pairs connus avec leur statut
POST	/peers/{id}/heartbeat	Signal de présence d’un pair
POST	/peers/goodbye	Retrait propre d’un pair de la coalition
<i>Mitigation collaborative</i>		
POST	/alert	Signalement d’une nouvelle attaque détectée
POST	/help/request	Demande d’aide à un pair pour une attaque
PUT	/help/{id}/accept	Acceptation d’une session d’aide
PUT	/help/{id}/reject	Refus d’une session d’aide
POST	/traffic/redirect	Activation de la redirection du flux
POST	/attack/over	Clôture de l’attaque et mise à jour des crédits
<i>Confiance et sélection</i>		
GET	/trust/{peer_id}	Score de confiance et ledger d’un pair
POST	/trust/{peer_id}/recalculate	Recalcul forcé du score de confiance
POST	/trust/select-peers	Sélection des pairs via WSM
<i>Sécurité</i>		
POST	/auth/token	Obtention d’un JWT signé RS256

Toutes les routes (sauf /auth/token et /peers/register) requièrent un JWT valide dans l’en-tête **Authorization**. Les réponses suivent la convention HTTP standard : 200/201 pour les succès, 400 pour les entrées invalides, 401/403 pour les accès non autorisés, 404 pour les ressources absentes.

3.4 Conclusion

Ce chapitre a présenté l’architecture complète du système. La coalition adopte une topologie P2P plate, chaque nœud gérant localement son registre de pairs, ses scores de confiance et ses politiques de participation. Le modèle PeerTrust adapté introduit une crédibilité historique par session, rendant le calcul de $T(u)$ plus fidèle à la réalité temporelle

du réseau. L'algorithme WSM avec pondération AHP offre une sélection multicritère équilibrée entre capacité, latence, confiance et réciprocité. Enfin, la double sécurisation mTLS + JWT RS256 garantit l'authenticité de chaque communication sans secret partagé.

Le chapitre suivant détaille l'implémentation concrète de ces mécanismes et présente les résultats des tests de scalabilité.

Chapitre 4

Implémentation et Évaluation

4.1 Introduction

Ce chapitre décrit la réalisation concrète du système. Après avoir présenté l'environnement technique retenu, nous détaillons l'implémentation des trois composants algorithmiques centraux : le gestionnaire de confiance (PeerTrust), le sélecteur de pairs (WSM) et les mécanismes de sécurité (mTLS + JWT RS256). Le chapitre se conclut par les résultats des tests de scalabilité conduits sur une coalition simulée jusqu'à 100 nœuds.

4.2 Environnement technique

4.2.1 Pile technologique

Le Tableau 4.1 présente les technologies utilisées et les motivations de chaque choix.

TABLE 4.1 – Pile technologique du système.

Composant	Technologie	Justification
Runtime serveur	Node.js 20 LTS	Modèle événementiel adapté aux I/O concurrentes (heartbeats, requêtes inter-nœuds)
Framework REST	Express.js 4	Minimaliste, middleware-first, large écosystème de plugins de sécurité
Base de données	PostgreSQL 15	ACID, support natif UUID, types ENUM, contraintes de clés étrangères
ORM	Sequelize 6	Abstraction SQL avec migrations, associations déclaratives
Authentification	jsonwebtoken (JWT)	Implémentation RS256 selon RFC 7519 [7]
Documentation API	Swagger/OpenAPI 3	Auto-documentation des endpoints via annotations JSDoc
Containerisation	Docker + Compose	Déploiement reproductible ; isolation réseau entre nœuds simulés

4.2.2 Structure du projet

Le projet est organisé selon le schéma de la Figure 4.1, séparant clairement la logique métier (`utils/`), les routes API (`routes/`), les modèles de données (`models/`) et la configuration (`config/`).



FIGURE 4.1 – Structure des répertoires du projet.

4.3 Implémentation du gestionnaire de confiance

4.3.1 Calcul de $T(u)$ avec Cr historique

Le module `utils/trustManager.js` implémente la formule PeerTrust (Équation 3.1). La fonction `computeTrustScore(peer_id)` charge toutes les sessions complétées du pair et calcule la moyenne pondérée :

```
1 async function computeTrustScore(peer_id) {
2   const sessions = await HelpSession.findAll({
3     where: { helping_peer_id: peer_id, status: "COMPLETED" },
4     include: [{ model: Attack, as: "attack",
5                 attributes: ["severity"] }],
6   });
7
8   if (sessions.length === 0)
9     return { score: DEFAULT_TRUST, level: "BRONZE", session_count: 0 };
10
11   let numerator = 0, denominator = 0;
12
13   for (const session of sessions) {
14     const accepted = Number(session.accepted_volume_gbps ?? 0);
15     const actual    = Number(session.actual_volume_gbps    ?? 0);
16   }
```



```

17 // S(u,i) = min(1, V_reel / V_accepte)
18 const S = accepted > 0 ? Math.min(1, actual / accepted) : 0;
19
20 // D(u,i) : facteur contextuel selon la severite
21 const severity = session.attack?.severity ?? "LOW";
22 const D = SEVERITY_WEIGHTS[severity] ?? 0.25;
23
24 // Cr_i : credibilite capturee a la cloture de la session
25 const Cr_i = session.cr_value ?? DEFAULT_TRUST;
26
27 numerator += S * Cr_i * D;
28 denominator += Cr_i * D;
29 }
30
31 const score = denominator > 0 ? numerator / denominator :
32   DEFAULT_TRUST;
33 return { score, level: scoreToLevel(score),
34   session_count: sessions.length };

```

Listing 4.1 – Calcul de T(u) avec crédibilité historique par session.

La valeur `cr_value` est persistée dans `HELP_SESSIONS` à la clôture de chaque attaque (route `POST /attack/over`), comme décrit à la section 4.3.2.

4.3.2 Capture de la crédibilité à la clôture

La fonction `fetchCrFromNetwork(localNodeId, excludePeerId)` interroge tous les pairs actifs (sauf le pair évalué) pour obtenir leur score de confiance courant du nœud local, puis retourne la moyenne :

```

1 // Dans POST /attack/over -- routes/coalition.js
2 const localNodeId = await getLocalNodeId();
3 const crCache = {}; // evite les appels en double par pair
4
5 for (const session of sessions) {
6   // ... mise a jour actual_volume_gbps ...
7
8   if (localNodeId) {
9     const pid = session.helping_peer_id;
10    if (crCache[pid] === undefined)
11      crCache[pid] = await fetchCrFromNetwork(localNodeId, pid);
12
13    await session.update({ cr_value: crCache[pid] });
14  }
15
16   // ... mise a jour du ledger de reciprocite ...
17 }

```

Listing 4.2 – Capture de Cr et persistance à la clôture de session.

Le cache `crCache` évite d'interroger le réseau plusieurs fois pour un même pair si plusieurs sessions concernent ce pair dans la même attaque. Le résultat est stocké dans `HELP_SESSIONS.cr_value` (FLOAT, valeur par défaut 0.5 pour les sessions antérieures à cette version).

4.3.3 Persistance et sanctions automatiques

La fonction `recalculateAndSave(peer_id)` recalcule le score, le persiste dans `TRUST_SCORES` et applique automatiquement la sanction si le score tombe sous 0.20 :

- Le champ `trust_level` de la table `TRUST_SCORES` est mis à jour.
- Si le niveau devient `BANNED` : le pair est marqué `status = BANNED` et `membership_status = EXPELLED` dans la table `PEERS`.
- Tout changement de niveau déclenche une entrée dans `AUDIT_LOG` (type `TRUST_LEVEL_CHANGED`).
- Un bannissement automatique génère une entrée de sévérité `CRITICAL` (`PEER_BANNED`).

4.4 Implémentation de la sélection des pairs

4.4.1 Calcul du score WSM

Le module `utils/peerSelector.js` implémente l'Équation 3.2. La fonction `selectPeers()` charge tous les pairs `ACTIVE` avec capacité disponible, normalise les valeurs brutes, puis calcule le score composite de chaque candidat :

```
1  const W = { C: 0.52, L: 0.20, T: 0.20, R: 0.08 };
2  const EPSILON = 1e-6;
3
4  // Normalisation des valeurs brutes
5  const maxCap = Math.max(...capValues);
6  const minLat = Math.min(...latValues);
7  const latRange = Math.max(...latValues) - minLat;
8
9  const scored = candidates.map((peer, i) => {
10     const Cp = maxCap > 0 ? capValues[i] / maxCap :
11       0;
12     const Lp_inv = latRange > 0 ? 1 - (latValues[i] - minLat) / latRange :
13       1;
14     const Tp = peer.trust_score?.overall_score ?? 0.5;
15
16     const received = Number(peer.reciprocity_ledger?.credits_received ??
17       0);
18     const given = Number(peer.reciprocity_ledger?.credits_given ??
19       0);
20     const Rp = received / (received + given + EPSILON);
21
22     const score = W.C*Cp + W.L*Lp_inv + W.T*Tp + W.R*Rp;
23     return { peer, score, criteria: { Cp, Lp_inv, Tp, Rp } };
24 });
```

Listing 4.3 – Calcul du score WSM et normalisation des critères.

4.4.2 Plan de répartition proportionnelle

Le plan de répartition est construit en normalisant les scores WSM ; l'allocation en pourcentage est la partie entière de $w_i \times 100$:

```
1  const totalScore = scored.reduce((s, c) => s + c.score, 0);
2
3  const plan = scored.map((c) => {
4     const weight = totalScore > 0
5       ? c.score / totalScore
```

```

6           : 1 / scored.length;
7   const allocation_pct = Math.floor(weight * 100);
8
9   const entry = { peer: { ... }, wsm_score, weight, allocation_pct };
10
11   // Si le volume total est connu, plafonner par la capacite reelle
12   if (overflowGbps !== undefined && overflowGbps > 0) {
13     const raw = weight * overflowGbps;
14     entry.estimated_gbps = Math.min(raw, c.cap_disp);
15   }
16   return entry;
17 });

```

Listing 4.4 – Construction du plan de répartition proportionnelle.

Le plafonnement par `cap_disp` garantit qu'aucun pair ne reçoit plus de trafic que sa capacité déclarée.

4.5 Mécanismes de sécurité

4.5.1 JWT RS256 : génération et vérification

Chaque nœud génère ses tokens avec sa clé privée RSA; la vérification utilise la clé publique de l'émetteur, stockée dans `PEERS.public_key` :

```

1 // Generation (noeud emetteur)
2 function generateToken(node_id) {
3   const privateKey = fs.readFileSync(process.env.TLS_KEY);
4   return jwt.sign(
5     { iss: node_id, node_id },
6     privateKey,
7     { algorithm: "RS256", expiresIn: "60s" }
8   );
9 }
10
11 // Verification (noeud recepteur) -- extrait du middleware
12 const decoded = jwt.decode(token); // lecture iss sans verif
13 const peer = await Peer.findOne({ where: { peer_id: decoded.iss } });
14 const publicKey = peer.public_key; // PEM stocke en base
15 jwt.verify(token, publicKey, { algorithms: ["RS256"] });

```

Listing 4.5 – Génération et vérification JWT RS256.

Le token expire après 60 secondes; un token expiré retourne HTTP 401 avec un message invitant à obtenir un nouveau token via `POST /auth/token`.

4.5.2 mTLS : configuration côté serveur

Le serveur HTTPS est créé avec les options TLS suivantes :

```

1 const server = https.createServer({
2   key: fs.readFileSync(process.env.TLS_KEY),
3   cert: fs.readFileSync(process.env.TLS_CERT),
4   ca: fs.readFileSync(process.env.TLS_CA),
5   requestCert: true, // demander le certificat client
6   rejectUnauthorized: process.env.MTLS_STRICT === "true",

```

```
7 }, app);
```

Listing 4.6 – Configuration mTLS du serveur HTTPS.

En mode `MTLS_STRICT=true`, toute connexion sans certificat client valide est rejetée au niveau TLS avant même d’atteindre les middlewares applicatifs. En mode non strict, le certificat est optionnel ; cela permet à des outils de test (Postman, Swagger UI) de s’y connecter sans certificat.

4.6 Protocole de communication inter-nœuds

Les nœuds communiquent exclusivement via des requêtes HTTPS authentifiées par JWT RS256. Cette section présente les messages JSON échangés lors des principales interactions du protocole.

4.6.1 Authentication

Avant tout appel API protégé, un nœud obtient un token JWT en transmettant son identifiant et son secret local.

```
1 // Requête
2 {
3   "node_id":      "node-university",
4   "node_secret": "secret-key-2025"
5 }
6
7 // Réponse 200 OK
8 {
9   "token":        "eyJhbGciOiJSUzI1NiJ9...",
10  "expires_in":   "60s",
11  "node_id":      "node-university",
12  "role":         "local",
13  "algorithm":    "RS256"
14 }
```

Listing 4.7 – Requête et réponse — POST /auth/token.

Le token expire après 60 secondes afin de limiter les attaques par rejeu. Le nœud récepteur vérifie la signature RS256 à l’aide de la clé publique de l’émetteur, enregistrée dans la table `Peers`.

4.6.2 Heartbeat

Chaque nœud envoie périodiquement un heartbeat à ses pairs pour signaler son état et sa charge courante.

```
1 // Requête
2 {
3   "peer_id":      "550e8400-e29b-41d4-a716-446655440000",
4   "reported_status": "ACTIVE",
5   "reported_load_pct": 42.5,
6   "reported_available_gbps": 5.75,
7   "round_trip_time_ms": 12
8 }
9
```

```

10 // Réponse 201 Created
11 {
12   "message": "Heartbeat recorded",
13   "heartbeat": {
14     "peer_id": "550e8400-...",
15     "reported_status": "ACTIVE",
16     "reported_load_pct": 42.5,
17     "reported_available_gbps": 5.75,
18     "round_trip_time_ms": 12
19   }
20 }

```

Listing 4.8 – Requête et réponse — POST /heartbeat.

À la réception, le nœud met à jour le champ `last_heartbeat` du pair et remet à zéro son compteur `consecutive_missed_heartbeats`.

4.6.3 Détection d'une attaque

Lorsqu'une attaque DDoS est détectée, le nœud victime l'enregistre localement via POST /alert.

```

1 // Requête
2 {
3   "target_ip_range": "192.168.1.0/24",
4   "target_service": "HTTP",
5   "target_port": 80,
6   "target_protocol": "TCP",
7   "status": "DETECTED",
8   "coalition_helped": false
9 }
10
11 // Réponse 201 Created
12 {
13   "attack_id": "a1b2c3d4-...",
14   "status": "DETECTED",
15   "severity": "LOW",
16   "detected_at": "2026-05-22T10:00:00.000Z",
17   "target_ip_range": "192.168.1.0/24",
18   "coalition_helped": false
19 }

```

Listing 4.9 – Requête et réponse — POST /alert.

La sévérité est initialisée à `LOW` et recalculée à la clôture de l'attaque en fonction du volume total filtré par la coalition.

4.6.4 Demande et réponse d'aide

Le nœud victime envoie une demande d'aide à chaque pair sélectionné par l'algorithme WSM.

```

1 // Requête
2 {
3   "attack_id": "a1b2c3d4-...",
4   "helping_peer_id": "550e8400-...",
5   "requesting_node_id": "node-university",

```

```

6  "allocation_pct": 60,
7  "tunnel_type":   "GRE"
8  }
9
10 // Réponse 201 Created
11 {
12  "session_id":      "f9e8d7c6-...",
13  "attack_id":       "a1b2c3d4-...",
14  "helping_peer_id": "550e8400-...",
15  "requesting_node_id": "node-university",
16  "status":          "REQUESTED",
17  "allocation_pct": 60,
18  "direction":       "OUTBOUND_REQUEST",
19  "requested_at":     "2026-05-22T10:00:05.000Z"
20 }

```

Listing 4.10 – Requête et réponse — POST /help/request.

Le pair accepte ou rejette la session après vérification du score de confiance et de sa capacité disponible.

```

1  // Acceptation - corps de la requête
2  {
3  "accepted_volume_gbps": 8.5,
4  "tunnel_type":          "GRE",
5  "response_time_ms":     230
6  }
7  // Réponse 200 OK
8  {
9  "session_id":           "f9e8d7c6-...",
10 "status":               "ACCEPTED",
11 "accepted_volume_gbps": 8.5,
12 "tunnel_type":          "GRE",
13 "responded_at":         "2026-05-22T10:00:06.000Z"
14 }
15
16 // Rejet - corps de la requête
17 { "rejection_reason": "Capacité insuffisante" }
18 // Réponse 200 OK
19 {
20 "session_id":           "f9e8d7c6-...",
21 "status":               "REJECTED",
22 "rejection_reason":     "Capacité insuffisante",
23 "responded_at":         "2026-05-22T10:00:06.000Z"
24 }

```

Listing 4.11 – Acceptation (PUT /help/{id}/accept) et rejet (PUT /help/{id}/reject).

4.6.5 Redirection du trafic et clôture

Une fois la session acceptée, le nœud victime déclenche la redirection du trafic vers le pair via un tunnel réseau.

```

1  // Requête
2  {
3  "session_id":  "f9e8d7c6-...",
4  "tunnel_type": "GRE",

```

```

5     "volume_gbps": 8.5
6 }
7
8 // Réponse 200 OK
9 {
10     "session_id":      "f9e8d7c6-...",
11     "status":          "ACTIVE",
12     "tunnel_type":     "GRE",
13     "actual_volume_gbps": 8.5,
14     "activated_at":    "2026-05-22T10:00:07.000Z"
15 }

```

Listing 4.12 – Requête et réponse — POST /traffic/redirect.

À la fin de l'attaque, le nœud victime clôture toutes les sessions et déclenche la mise à jour des crédits de réciprocité.

```

1 // Requête
2 {
3     "attack_id":      "a1b2c3d4-...",
4     "session_ids":    ["f9e8d7c6-..."],
5     "attack_duration_seconds": 300
6 }
7
8 // Réponse 200 OK
9 {
10     "attack_id":      "a1b2c3d4-...",
11     "status":          "ENDED",
12     "severity":        "HIGH",
13     "ended_at":        "2026-05-22T10:05:00.000Z",
14     "duration_seconds": 300,
15     "coalition_helped": true,
16     "nb_peers_involved": 1
17 }

```

Listing 4.13 – Requête et réponse — POST /attack/over.

La sévérité finale est calculée selon l'échelle Stormwall : **CRITICAL** (≥ 100 Gbps filtrés), **HIGH** (≥ 10 Gbps), **MEDIUM** (≥ 1 Gbps), **LOW** (en dessous).

4.7 Tests et évaluation

4.7.1 Protocole de test

Les tests ont été conduits selon trois axes :

1. **Tests fonctionnels** (tests/functional_test.py) : vérification de chaque endpoint de l'API (enregistrement, heartbeat, sessions d'aide, clôture, recalcul de trust).
2. **Tests de sécurité** (tests/security_test.py) : tentatives d'accès sans JWT, avec un token expiré, avec un token signé par une clé incorrecte, et avec un nœud banni.
3. **Tests de scalabilité** (tests/scalability_test.py) : montée en charge progressive de 20 à 100 nœuds simultanés ; mesure des temps de réponse pour l'enregistrement, le heartbeat et la sélection WSM.

Les tests de scalabilité ont été conduits sur une machine locale avec Node.js 20 LTS et PostgreSQL 15, en simulant les nœuds par des processus Python concurrents via `asyncio` et `aiohttp`.

4.7.2 Résultats des tests de scalabilité

Le Tableau 4.2 présente les résultats collectés ; la Figure 4.2 en offre une représentation graphique.

TABLE 4.2 – Résultats des tests de scalabilité (20 à 100 nœuds).

Nœuds	Enregistrement			Heartbeat			Sélection WSM	
	OK	Moy (ms)	Max (ms)	OK	Moy (ms)	Max (ms)	Durée (ms)	Pairs
20	20	389	420	20	160	178	32.2	20
40	40	313	382	40	220	247	22.5	40
60	60	426	511	60	280	307	20.8	60
80	80	449	565	80	450	490	28.6	80
100	100	457	550	100	407	434	30.4	100

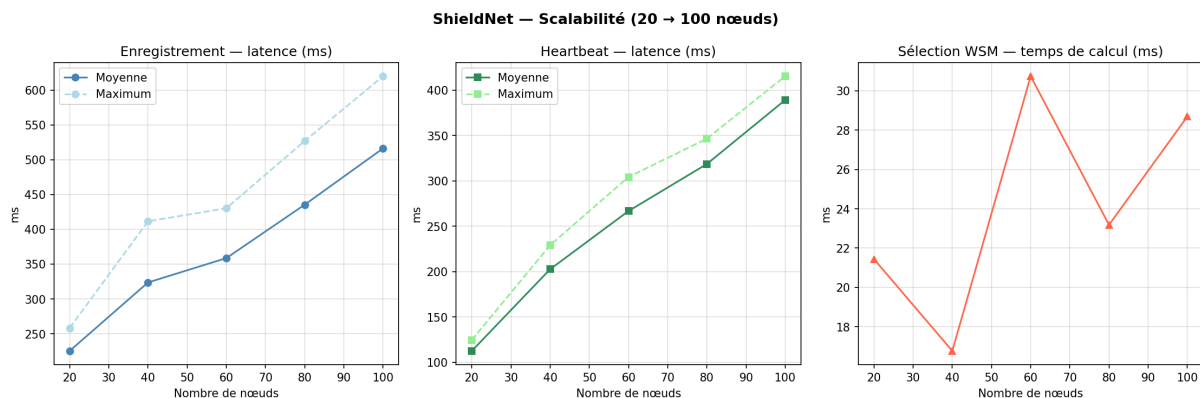


FIGURE 4.2 – Temps de réponse en fonction du nombre de nœuds simulés (enregistrement, heartbeat et sélection WSM).

4.8 Conclusion

Ce chapitre a présenté l'implémentation complète du système et ses résultats d'évaluation. Le gestionnaire de confiance implémente fidèlement la formule PeerTrust avec une crédibilité historique par session, garantissant que chaque session est évaluée avec la réputation en vigueur à l'époque des faits. L'algorithme WSM offre une sélection multicritère en moins de 33 ms même pour 100 nœuds simultanés. La double sécurisation mTLS + JWT RS256 assure l'authenticité de chaque communication sans secret partagé entre les nœuds.

Les tests de scalabilité confirment que le système maintient un taux de succès de 100 % sur l'ensemble des fonctionnalités testées jusqu'à 100 nœuds, avec des temps de

réponse compatibles avec les contraintes opérationnelles d'une coalition de mitigation collaborative.

Bibliographie

- [1] W. T. CHUA, *Memcrashed — Major Amplification Attacks from UDP Port 11211*, Cloudflare Blog, 2018. adresse : <https://blog.cloudflare.com/memcrashed-major-amplification-attacks-from-port-11211/>
- [2] CLOUDFLARE, « DDoS Threat Report — Q1 2025, » Cloudflare, Inc., rapp. tech., 2025. adresse : <https://blog.cloudflare.com/ddos-threat-report-2025-q1>
- [3] C. DOULIGERIS et A. MITROKOTSA, « DDoS Attacks and Defense Mechanisms : Classification and State-of-the-Art, » *Computer Networks*, t. 44, n° 5, p. 643-666, 2004.
- [4] W. EDDY, *TCP SYN Flooding Attacks and Common Mitigations*, RFC 4987, 2007.
- [5] R. T. FIELDING, « Architectural Styles and the Design of Network-based Software Architectures, » thèse de doct., University of California, Irvine, 2000. adresse : <https://www.ics.uci.edu/~fielding/pubs/dissertation/top.htm>
- [6] M. B. JONES, *JSON Web Algorithms (JWA)*, RFC 7518, 2015.
- [7] M. B. JONES, J. BRADLEY et N. SAKIMURA, *JSON Web Token (JWT)*, RFC 7519, 2015.
- [8] W. KUMARI et D. MCPHERSON, *Remote Triggered Black Hole Filtering with Unicast Reverse Path Forwarding (uRPF)*, RFC 5635, 2009.
- [9] R. MAHAJAN et al., « Controlling High Bandwidth Aggregates in the Network, » *ACM SIGCOMM Computer Communication Review*, t. 32, n° 3, p. 62-73, 2002.
- [10] P. MARQUES et al., *Dissemination of Flow Specification Rules*, RFC 5575, 2009.
- [11] J. MIRKOVIC, G. PRIER et P. REIHER, « DefCOM : Distributed Cooperative Overlay Defense Against DDoS Attacks, » in *Proceedings of the IEEE International Conference on Network Protocols (ICNP)*, IEEE, 2003, p. 239-250.
- [12] J. MIRKOVIC et P. REIHER, « A Taxonomy of DDoS Attack and DDoS Defense Mechanisms, » *ACM SIGCOMM Computer Communication Review*, t. 34, n° 2, p. 39-53, 2004.
- [13] J. MIRKOVIC et P. REIHER, « D-WARD : A Source-End Defense Against Flooding Denial-of-Service Attacks, » *IEEE Transactions on Dependable and Secure Computing*, t. 2, n° 3, p. 216-232, 2005.
- [14] A. MORTENSEN, T. REDDY et R. MOSKOWITZ, *Distributed Denial-of-Service Open Threat Signaling (DOTS) Requirements*, RFC 8612, 2019.
- [15] NBIP, « NaWas : National Scrubbing Center for DDoS Attacks, » Nationale Beheersorganisatie Internet Providers, rapp. tech., 2023.

- [16] NETSCOUT SYSTEMS, « NETSCOUT Threat Intelligence Report — 1st Half 2023, » NETSCOUT Systems, rapp. tech., 2023.
- [17] T. REDDY et al., *Distributed Denial-of-Service Open Threat Signaling (DOTS) Signal Channel Specification*, RFC 8782, 2020.
- [18] Y. REKHTER, T. LI et S. HARES, *A Border Gateway Protocol 4 (BGP-4)*, RFC 4271, 2006.
- [19] E. RESCORLA, *The Transport Layer Security (TLS) Protocol Version 1.3*, RFC 8446, 2018.
- [20] C. ROSSOW, « Amplification Hell : Revisiting Network Protocols for DDoS Abuse, » in *Proc. Network and Distributed System Security Symposium (NDSS)*, 2014.
- [21] T. L. SAATY, *The Analytic Hierarchy Process : Planning, Priority Setting, Resource Allocation*. New York : McGraw-Hill, 1980.
- [22] SIDN LABS, « DDoS Clearing House : Sharing DDoS Attack Fingerprints to Improve Collective Defense, » CONCORDIA H2020 Project, rapp. tech., 2021.
- [23] S. M. SPECHT et R. B. LEE, « Distributed Denial of Service : Taxonomies of Attacks, Tools, and Countermeasures, » in *Proc. International Workshop on Security in Parallel and Distributed Systems*, 2004, p. 543-550.
- [24] I. STOICA et al., « Chord : A Scalable Peer-to-Peer Lookup Service for Internet Applications, » in *Proc. ACM SIGCOMM*, 2001, p. 149-160.
- [25] STORMWALL, *DDoS Severity Level*, StormWall Network, FAQ, Consulté le 11 mai 2026, 2024. adresse : <https://stormwall.network/resources/instructions/faq/ddos-severity-level>
- [26] A. S. TANENBAUM et M. VAN STEEN, *Distributed Systems : Principles and Paradigms*, 3rd. Pearson Education, 2017.
- [27] L. XIONG et L. LIU, « PeerTrust : Supporting Reputation-Based Trust for Peer-to-Peer Electronic Communities, » *IEEE Transactions on Knowledge and Data Engineering*, t. 16, n° 7, p. 843-857, juill. 2004. DOI : 10.1109/TKDE.2004.1318566
- [28] S. T. ZARGAR, J. JOSHI et D. TIPPER, « A Survey of Defense Mechanisms Against Distributed Denial of Service (DDoS) Flooding Attacks, » *IEEE Communications Surveys & Tutorials*, t. 15, n° 4, p. 2046-2069, 2013.